LAKSHMI NARAIN COLLEGE OF TECHNOLOGY (MCA), BHOPAL



MCA First Semester

MCA-104: Information Technology

UNIT-II

NOTES

Prepared by

Dr. Virendra Kumar Tiwari

DR. VIRENDRA KUMAR TIWARI

Syllabus	
	MCA-104: Information Technology
Unit	**Contents (*Theory*)**
II	Information Security: Introduction, malicious programs, Cryptography, digital signature, Firewall, Users Identification and Authentication, Security awareness and policies, Application areas requiring security. Mobile Commerce: Introduction, Growth, Success Stories of Mobile commerce, Technologies for mobile commerce, M-commerce in India, Digital Marketing.

INFORMATION SECURITY

Introduction of Information Security?

The protection of information and information systems from unauthorized access, use, or disruption.

It is important for all stakeholders to understand information security policies and guidelines. It is also necessary to have good work practices that comply with security policies so that the effects of possible breaches can be minimized.

Information Security is not only about securing information from unauthorized access. Information Security is basically the practice of preventing unauthorized access, use, disclosure, disruption, modification, inspection, recording or destruction of information. Information can be physical or electronic one. Information can be anything like Your details, or we can say your profile on social media, your data in mobile phone, your biometrics etc. Thus, Information Security spans so many research areas like Cryptography, Mobile Computing, Cyber Forensics, Online social media etc.

During the First World War, Multi-tier Classification System was developed keeping in mind sensitivity of information. With the beginning of Second World War formal alignment of Classification System was done. Alan Turing was the one who successfully decrypted Enigma Machine which was used by Germans to encrypt warfare data.

Why is it important to keep the University network secure?

- **Data theft:** Hackers accessing student or employee personal or confidential details.
- **Data loss:** Unauthorized entities manipulating or deleting important data.
- **Lawsuits** against the University.
- Loss of **Reputation**.
- **Financial loss** including recovery expenses.

TYPES OF INFORMATION SECURITY

Some of the types of Information Security are:

- **Application Security:** This covers a wide area of vulnerabilities in software, web, and application programming interfaces. The vulnerabilities can exist in user authentication and other areas which can create entry points for potential threats and information security breaches.
- **Information Security:** This refers to the security of the entire infrastructure related to this area.

- **Cloud Security:** This refers to the shared cloud environment and information security for the building and hosting a secure infrastructure for client applications.
- **Cryptography:** Encryption and Cryptography play a big part in information security in many fields. A beginner can easily relate to the encrypted messaging in WhatsApp to prevent information breaches when transmitted between two individuals.
- **Vulnerability Management:** This is the process of screening all system areas to find out any potential weak zones. This is critical in an era where organizations are continually upgrading their hardware and adding new applications where any weak and vulnerable points need to be plugged in at the earliest.

Ensuring Security

The key areas to consider when safeguarding the University's information and assets are listed below:

1. Update your software.

- New versions of the software have been released to address security problems that have been found. Updating your software ensures you take full advantage of all the security upgrades.
- If you do not update the software, you can put your computer at risk of viruses and other problems because the software is no longer supported.

2. Use anti-virus software.

- Anti-virus companies spend their time ensuring their software helps stop known viruses. If you have a current and up-to-date version, you can be assured that the software is looking for problems and blocking them.

3. Be suspicious of unsolicited phone calls or emails.

- Unsolicited emails and phone calls are trying to get you to do something that will benefit someone else. It might be just spam trying to get you to buy things, or it might be trying to get you to access something that will put a virus on your computer or give others access to your information**.**

4. Back up your data.

- If you have a problem with your computer and it needs to be reset or even replaced, you will still have access to your information if you back it up.

5. Use legitimate software.

You should always use legitimate software that you have purchased from a vendor or downloaded from the company's website. Why?

- Using pirated copies of software on university devices will mean that the University could be prosecuted if discovered.
- If you use pirated copies, you open your computer to viruses that you may not know about. The software itself may contain a virus, or it won't be supported by the vendor, meaning you won't receive regular security updates.

6. Set strong passwords and use different passwords for different accounts.

- A password that is strong and changed regularly makes it harder for people to access your information.
- If you use the same password for all your accounts and one account is compromised, the person accessing your account is more likely to be able to guess all your other passwords and access those accounts too.
- If you store an unencrypted list of your passwords on your computer and someone gains access to the computer, they then have all your passwords.

8. Do not lose your device.

- If someone gets your device, they may have access to all your information and plenty of time to access it.

DR. VIRENDRA KU

MALICIOUS PROGRAMS

Malware definition

Malware, short for *malicious software,* is a blanket term for viruses, worms, trojans and other harmful computer programs hackers use to wreak destruction and gain access to sensitive information. As Microsoft puts it, "[malware] is a catch-all term to refer to any software designed to cause damage to a single computer, server, or computer network." In other words, software is identified as malware based on its *intended use,* rather than a particular technique or technology used to build it.

This means that the question of, say, what the difference is between malware and a virus misses the point a bit: a virus is a type of malware, so all viruses are malware (but not every piece of malware is a virus).

Types of malwares

1. Virus

Viruses are a subgroup of malware. A virus is malicious software attached to a document or file that supports macros to execute its code and spread from host to host. Once downloaded, the virus will lay dormant until the file is opened and in use. Viruses are designed to disrupt a system's ability to operate. As a result, viruses can cause significant operational issues and data loss.

(First Computer Virus Name: As noted by Discovery, the Creeper program, often regarded as the first virus, was created in 1971 by Bob Thomas of BBN. Creeper was designed as a security test to see if a self-replicating program was possible.

Creeper

Creeper was **a test created to demonstrate the possibility of a self-replicating computer program that could spread to other computers**. The program was not actively malicious software as it caused no damage to data, the only effect being a message it output to the teletype reading "I'M THE CREEPER: CATCH ME IF YOU CAN".)

What is the first computer virus in India?

The first computer virus in India is 'The Brain Virus'. It is a boot sector virus which was developed by two computer scientists from an Asian country. It was reported that all the floppy disks were affected by this virus

2. Worms

Worms are malicious software that rapidly replicates and spreads to any device within the network. Unlike viruses, worms do not need host programs to disseminate. A worm infects a device via a downloaded file or a network connection before it multiplies and disperses at an exponential rate. Like viruses, worms can severely disrupt the operations of a device and cause data loss.
(First computer worms' name: The Morris worm or Internet worm of November 2, 1988, is one of the oldest computer worms distributed via the Internet, and the first to gain significant mainstream media attention.)

3. Trojan virus

Trojan viruses are disguised as helpful software programs. But once the user downloads it, the Trojan virus can gain access to sensitive data and then modify, block, or delete the data. This can be extremely harmful to the performance of the device. Unlike normal viruses and worms, Trojan viruses are not designed to self-replicate.

4. Spyware

Spyware is malicious software that runs secretly on a computer and reports back to a remote user. Rather than simply disrupting a device's operations, spyware targets sensitive information and can grant remote access to predators. Spyware is often used to steal financial or personal information. A specific type of spyware is a keylogger, which records your keystrokes to reveal passwords and personal information.

5. Adware

Adware is malicious software used to collect data on your computer usage and provide appropriate advertisements to you. While adware is not always dangerous, in some cases adware can cause issues for your system. Adware can redirect your browser to unsafe sites, and it can even contain Trojan horses and spyware. Additionally, significant levels of awareness can slow down your system noticeably. Because not all adware is malicious, it is important to have protection that constantly and intelligently scans these programs.

6. Ransomware

Ransomware is malicious software that gains access to sensitive information within a system, encrypts that information so that the user cannot access it, and then demands a financial payout for the data to be released. Ransomware is commonly part of a phishing scam. By clicking a disguised link, the user downloads the ransomware. The attacker proceeds to encrypt specific information that can only be opened by a mathematical key they know. When the attacker receives payment, the data is unlocked.

7. Fileless malware

Fileless malware is a type of memory-resident malware. As the term suggests, it is malware that operates from a victim's computer's memory, not from files on the hard drive. Because there are no files to scan, it is harder to detect than traditional malware. It also makes forensics more

DR. VIRENDRA KUMAR TIWARI

difficult because the malware disappears when the victim computer is rebooted. In late 2017, the Cisco Talos threat intelligence team posted an example of fileless malware that they called DNS Messenger.

A. Prevent Malware (Malware protection):

With spam and phishing email being the primary vector by which malware infects computers, the best way to prevent malware is make sure your email systems are locked down tight—and your users know how to spot danger. We recommend a combination of carefully checking attached documents and restricting potentially dangerous user behavior—as well as just familiarizing your users with common phishing scams so that their common sense can kick in.

When it comes to more technical preventative measures, there are a number of steps you can take, including keeping all your systems patched and updated, keeping an inventory of hardware so you know what you need to protect, and performing continuous vulnerability assessments on your infrastructure. When it comes to ransomware attacks in particular, one way to be prepared is to always make backups of your files, ensuring that you'll never need to pay a ransom to get them back if your hard drive is encrypted.

Antivirus software is the most widely known product in the category of malware protection products; despite "virus" being in the name, most offerings take on all forms of malware. While high-end security pros dismiss it as obsolete, it's still the backbone of basic anti-malware defense. Today's best antivirus software is from vendors Kaspersky Lab, Symantec and Trend Micro, according to recent tests by AV-TEST.

When it comes to more advanced corporate networks, endpoint security offerings provide defense in depth against malware. They provide not only the signature-based malware detection that you expect from antivirus, but anti-spyware, personal firewall, application control and other styles of host intrusion prevention. Gartner offers a list of its top picks in this space, which include products from Cylance, CrowdStrike, and Carbon Black.

B. How to detect malware

It's fully possible—and perhaps even likely—that your system will be infected by malware at some point despite your best efforts. How can you tell for sure? *CSO* columnist Roger Grimes has written a deep dive into how to diagnose your PC for potential malware that you might find helpful.

When you get to the level of corporate IT, there are also more advanced visibility tools you can use to see what's going on in your networks and detect malware infections. Most forms of malware use the network to either spread or send information back to their controllers, so network traffic contains signals of malware infection that you might otherwise miss; there are a wide range of network monitoring tools out there, with prices ranging from a few dollars to a

few thousand. There are also SIEM tools, which evolved from log management programs; these tools analyze logs from various computers and appliances across your infrastructure looking for signs of problems, including malware infection. SIEM vendors range from industry stalwarts like IBM and HP Enterprise to smaller specialists like Splunk and Alien Vault.

C. Malware removal

How to remove malware once you're infected is in fact the million-dollar question. Malware removal is a tricky business, and the method can vary depending on the type you're dealing with. *CSO* has information on how to remove or otherwise recover from rootkits, ransomware, and cryptojacking. We also have a guide to auditing your Windows registry to figure out how to move forward.

If you're looking for tools for cleansing your system, Tech Radar has a good roundup of free offerings, which contains some familiar names from the antivirus world along with newcomers like Malwarebytes.

D. Malware Examples

We've already discussed some of the current malware threats looming large today. But there is a long, storied history of malware, dating back to infected floppy disks swapped by Apple II hobbyists in the 1980s and the Morris Worm spreading across Unix machines in 1988. Some of the other high-profile malware attacks have included:

- **ILOVEYOU**, a worm that spread like wildfire in 2000 and did more than $15 billion in damage
- **SQL Slammer**, which ground internet traffic to a halt within minutes of its first rapid spread in 2003
- **Conficker**, a worm that exploited unpatched flaws in Windows and leveraged a variety of attack vectors – from injecting malicious code to phishing emails – to ultimately crack passwords and hijack Windows devices into a botnet.
- **Zeus**, a late '00s keylogger Trojan that targeted banking information
- **CryptoLocker**, the first widespread ransomware attack, whose code keeps getting repurposed in similar malware projects
- **Stuxnet**, an extremely sophisticated worm that infected computers worldwide but only did real damage in one place: the Iranian nuclear facility at Natanz, where it destroyed uranium-enriching centrifuges, the mission it was built for by U.S. and Israeli intelligence agencies

E. Malware trends

You can count on cyber criminals to follow the money. They will target victims depending on the likelihood of delivering their malware successfully and the size of potential payout. If you look at malware trends over the past few years, you will see some fluctuation in terms of the

popularity of certain types of malwares and who the most common victims are—all driven by what the criminals believe will have the biggest ROI.

Recent research reports indicate some interesting shifts in malware tactics and targets. Crypto miners, which had surpassed ransomware as the most common type of malware, are falling out of favor due to the decline in cryptocurrency values. Ransomware is becoming more targeted, moving away from a shotgun approach.

F. Malware attacks on businesses spikes

Businesses saw a 79 percent increase in the amount of malware they dealt with in 2018 over 2017, according to the Malwarebytes Labs State of Malware Report 2019. "What we usually see year-end or quarterly end is that there has been some sort of increase or large amounts of detections on the consumer side," says Adam Kujawa, director of Malwarebytes Labs. "On the business side it might slowly grow, but certainly nothing like we've seen this last six months." By comparison, consumer detections decreased by 3 percent over the same period.

"We've observed that there is a significant push by cyber criminals to move away from consumers and put their really heavy stuff against businesses instead," Kujawa adds.

That "really heavy stuff" comes largely in the form of older consumer-focused malware that's "been weaponized" to become a bigger, more versatile threat for business. Kujawa cites Emotet as one of the most significant. "It's a nasty little information stealing Trojan that also installs additional malware, spreads laterally, and acts as its own spam sender. Once it infects a system, it starts sending email and tries to infect other people."

Emotet has been around since 2014 and targeted mainly consumers. Originally, it infected a computer looking for an individual's financial or credit card information to steal. Since then, it's picked up new capabilities inspired by or borrowed from other successful malware like WannaCry or EternalBlue. "Now it's become much more modular, and we see it able to use these exploits to traverse through a corporate network whereas before they were limited to a single endpoint," says Kujawa. "Even if it's a small network in a small business, it's more juicy than infecting Grandma."

Lateral movement of malware is increasing, according to the Global Threat Report: The Year of the Next-Gen Cyberattack from Carbon Black. Nearly 60 percent of malware attacks on business are now designed to move laterally across a network.

One reason for the spike in malware attacks on business might be the EU's General Data Privacy Regulation (GDPR). Kujawa believes it's possible that attackers stepped up business attacks thinking that it would be harder to steal personal and other data after the regulation went into effect. That combined with the decline of cryptocurrency values and stepped-up

defenses against ransomware turned attackers to what worked in the past. “They always [go back to what works],” he says. “Cybercrime is cyclical. It always comes back around.”

G. Cryptomining attacks decline

The Malwarebytes Labs report has seen a shift away from crypto mining starting in the second quarter of 2018, due largely to the decline in cryptocurrency values. Still, the number of crypto mining detections increased for the year by 7 percent.

Instead, cyber criminals are turning to information stealing malware like Emoted to turn a profit. “Overall, it seems as though criminals have reached the consensus that sometimes stealing is better than mining,” the report stated.

H. Ransomware becoming more targeted

Kujawa notes that small and medium-sized businesses (SMBs) are becoming more popular targets. He attributes this to the likelihood of being paid for ransomware attacks—SMBs often can’t afford the downtime and see paying ransom as the fastest way to recover. They also often have softer targets than larger businesses.

Ransomware detections declined by 26 percent worldwide in 2018, according to the Malwarebytes report. However, ransomware detections at businesses rose by 28 percent. Industries most often targeted were consulting, education, manufacturing and retail. Kujawa believes criminals focus on these industries because of the opportunity and likelihood of ransoms being paid.

DR. VIREN

CRYPTOGRAPHY

Basic Concepts

Cryptography The art or science encompassing the principles and methods of transforming an intelligible message into one that is unintelligible and then retransforming that message back to its original form.

Plaintext The original intelligible message.

Cipher text the transformed message.

Cipher An algorithm for transforming an intelligible message into one that is unintelligible by transposition and/or substitution methods.

Key Some critical information used by the cipher, known only to the sender& receiver.

Encipher (encode) The process of converting plain text to cipher text using a cipher and a key.

Decipher (decode) the process of converting cipher text back into plaintext using a cipher and a

Key.

Cryptanalysis The study of principles and methods of transforming an unintelligible message back into an intelligible message without knowledge of the key. Also called code breaking.

Cryptology Both cryptography and cryptanalysis.

Code An algorithm for transforming an intelligible message into an unintelligible one using a code-book Cryptograph.

DR. VIRENDRA KUMAR TIWARI

Cryptography:

Cryptographic systems are generally classified along 3 independent dimensions:

Type of operations used for transforming plain text to cipher text

All the encryption algorithms are based on two general principles: substitution, in which each element in the plaintext is mapped into another element, and transposition, in which elements in the plaintext are rearranged.

The number of keys used

If the sender and receiver uses same key then it is said to be symmetric key (or)

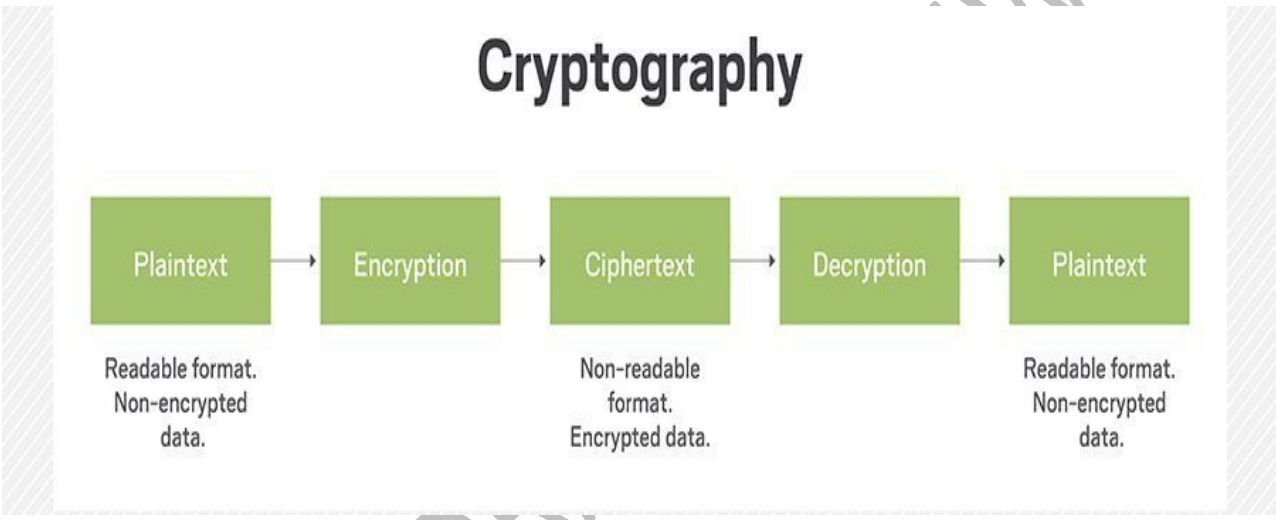
single key (or) conventional encryption.

If the sender and receiver use different keys, then it is said to be public key encryption.

The way in which the plain text is processed

A block cipher processes the input and block of elements at a time, producing output block for each input block.

A **stream cipher** processes the input elements continuously, producing output element one at a time, as it goes along.



Cryptanalysis:

The process of attempting to discover X or K or both is known as cryptanalysis. The strategy used by the cryptanalysis depends on the nature of the encryption scheme and the information available to the cryptanalyst.

There are various types of cryptanalytic attacks based on the amount of information known to the cryptanalyst.

Cipher text only – A copy of cipher text alone is known to the cryptanalyst.

Known plaintext – The cryptanalyst has a copy of the cipher text and the corresponding plaintext.

Chosen plaintext – The cryptanalysts gain temporary access to the encryption machine. They cannot open it to find the key, however; they can encrypt many suitably chosen plaintexts and try to use the resulting cipher texts to deduce the key.

Chosen cipher text – The cryptanalyst obtains temporary access to the decryption machine, uses it to decrypt several string of symbols, and tries to use the results to deduce the key.

Cryptographic algorithms:

Cryptosystems use a set of procedures known as cryptographic algorithms, or ciphers, to encrypt and decrypt messages to secure communications among computer systems, devices and applications.

Cryptographic algorithms are essential tools for securing digital data and communications. They work by transforming readable data, known as plaintext, into an unreadable form, called ciphertext, which can only be converted back to plaintext by authorized parties. Cryptographic algorithms are widely classified into three main categories: symmetric key algorithms, asymmetric key algorithms, and hash functions.

1. Symmetric Key Algorithms

In symmetric key cryptography, a single key is used for both encryption and decryption. The sender and the receiver must share this secret key securely before communication. These algorithms are generally faster than asymmetric algorithms and are suitable for large amounts of data.

- **AES (Advanced Encryption Standard):** A widely used symmetric encryption standard, AES is known for its security and efficiency. It supports key sizes of 128, 192, or 256 bits.
- **DES (Data Encryption Standard):** An older encryption standard with a 56-bit key, DES is now considered insecure due to its shorter key length.
- **3DES (Triple DES):** An enhancement over DES, applying DES encryption three times, it offers better security than DES but is slower compared to AES.
- **Blowfish and Twofish:** These are block ciphers known for their flexibility and efficiency, with Blowfish having variable-length keys up to 448 bits.

2. Asymmetric Key Algorithms

Asymmetric key cryptography, also known as public-key cryptography, uses a pair of keys: a public key, which can be shared openly, and a private key, which is kept secret. Only the private key can decrypt data encrypted with the public key, and vice versa. This is ideal for secure key exchange, digital signatures, and authentication.

- **RSA (Rivest-Shamir-Adleman):** One of the first and most popular public-key encryption methods, RSA is used extensively in secure data transmission. It relies on the computational difficulty of factoring large integers.
- **ECC (Elliptic Curve Cryptography):** ECC provides strong security with smaller key

DR. VIRENDRA KUMAR TIWARI

sizes than RSA, making it efficient and ideal for mobile and IoT devices.

- **DSA (Digital Signature Algorithm):** Primarily used for digital signatures, DSA is an asymmetric algorithm that ensures data integrity and authenticity.

3. Hash Functions

Hash functions are cryptographic algorithms that take an input and produce a fixed-size string of characters, usually a hash value or digest. They are used for data integrity checks, passwords, and digital signatures. Unlike encryption algorithms, hash functions are one-way; they cannot be decrypted back to the original data.

- **SHA (Secure Hash Algorithm):** SHA-1 is an older version, while SHA-256, SHA-384, and SHA-512 are newer and more secure variants in the SHA-2 family. These are widely used in digital signatures and certificates.
- **MD5 (Message Digest Algorithm):** Once popular, MD5 is now considered insecure due to vulnerability to collision attacks, where two different inputs produce the same hash.
- **SHA-3:** A newer hash function designed to provide an additional layer of security, SHA-3 is an alternative to the SHA-2 family.

Additional Concepts in Cryptography

- **Digital Signatures:** Used to verify the authenticity of a digital message or document, digital signatures use asymmetric algorithms like RSA or DSA.
- **Key Exchange Protocols:** Protocols like Diffie-Hellman allow secure key exchange over insecure channels, enabling secure communication even when keys cannot be shared directly.

These cryptographic algorithms form the backbone of secure online communication, digital transactions, and data protection. Each algorithm has its own strengths and applications, and they are often used together to create layers of security in modern cryptographic systems.

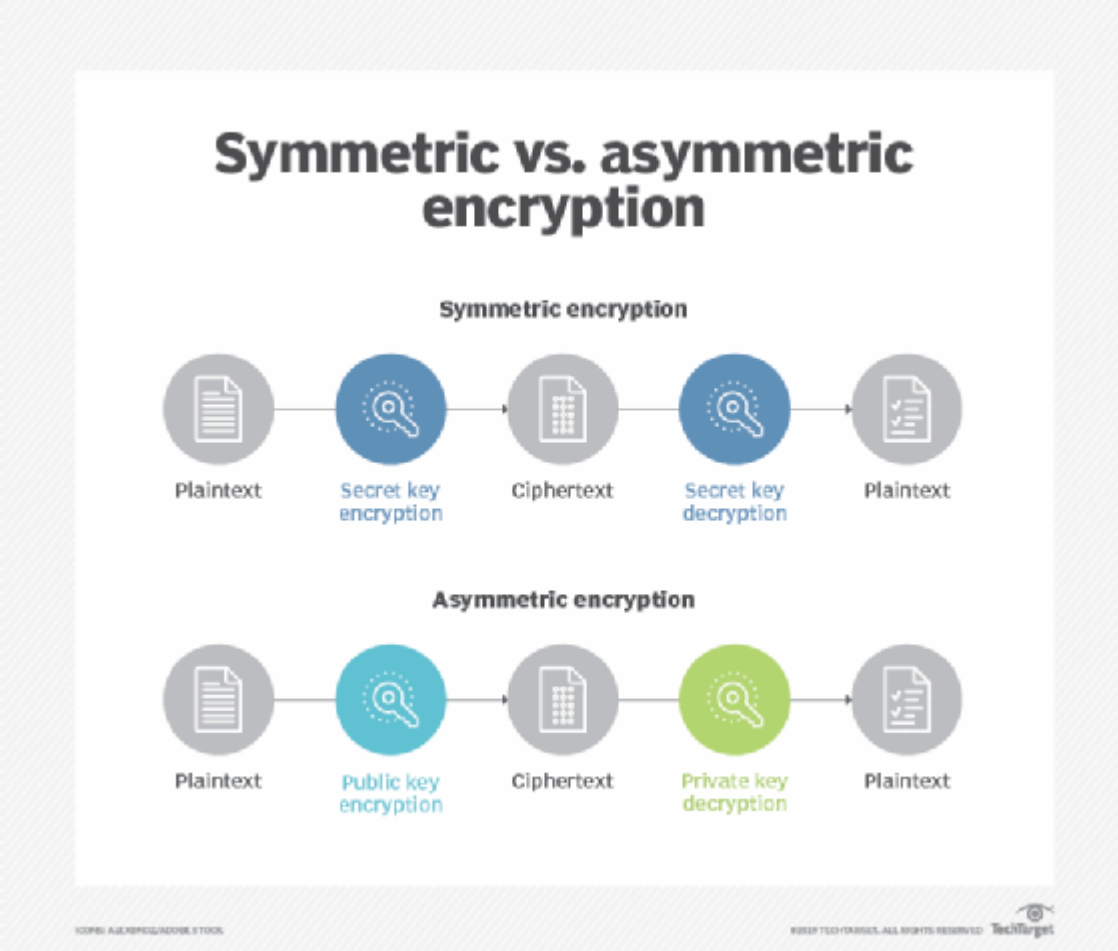
DR. VIRENDRA KUMAR TIWARI

Types of cryptography:

Single-key or symmetric-key encryption algorithms create a fixed length of bits known as a block cipher with a secret key that the creator/sender uses to encipher data (encryption) and the receiver uses to decipher it. One example of symmetric-key cryptography is the Advanced Encryption Standard (AES). AES is a specification established in November 2001 by the National Institute of Standards and Technology (NIST) as a Federal Information Processing Standard (FIPS

197) to protect sensitive information. The standard is mandated by the U.S. government and widely used in the private sector.

In June 2003, AES was approved by the U.S. government for classified information. It is a royalty-free specification implemented in software and hardware worldwide. AES is the successor to the Data Encryption Standard (DES) and DES3. It uses longer key lengths -- 128-bit, 192-bit, 256-bit -- to prevent brute force and other attacks.



Symmetric cryptography uses a single key while asymmetric cryptography uses a key pair to encrypt and decrypt data.

Public-key or asymmetric-key encryption algorithms use a pair of keys, a public key associated with the creator/sender for encrypting messages and a private key that only the originator knows (unless it is exposed, or they decide to share it) for decrypting that information.

Examples of public-key cryptography include:

- RSA, used widely on the internet.
- Elliptic Curve Digital Signature Algorithm (ECDSA) used by Bitcoin.
- Digital Signature Algorithm (DSA) adopted as a Federal Information Processing Standard for digital signatures by NIST in FIPS 186-4.
- Diffie-Hellman key exchange.

To maintain data integrity in cryptography, **hash functions**, which return a deterministic output from an input value, are used to map data to a fixed data size. Types of cryptographic hash functions include SHA-1 (Secure Hash Algorithm 1), SHA-2 and SHA-3.

DR. VIRENDRA KUMAR TIWARI

DIGITAL SIGNATURES

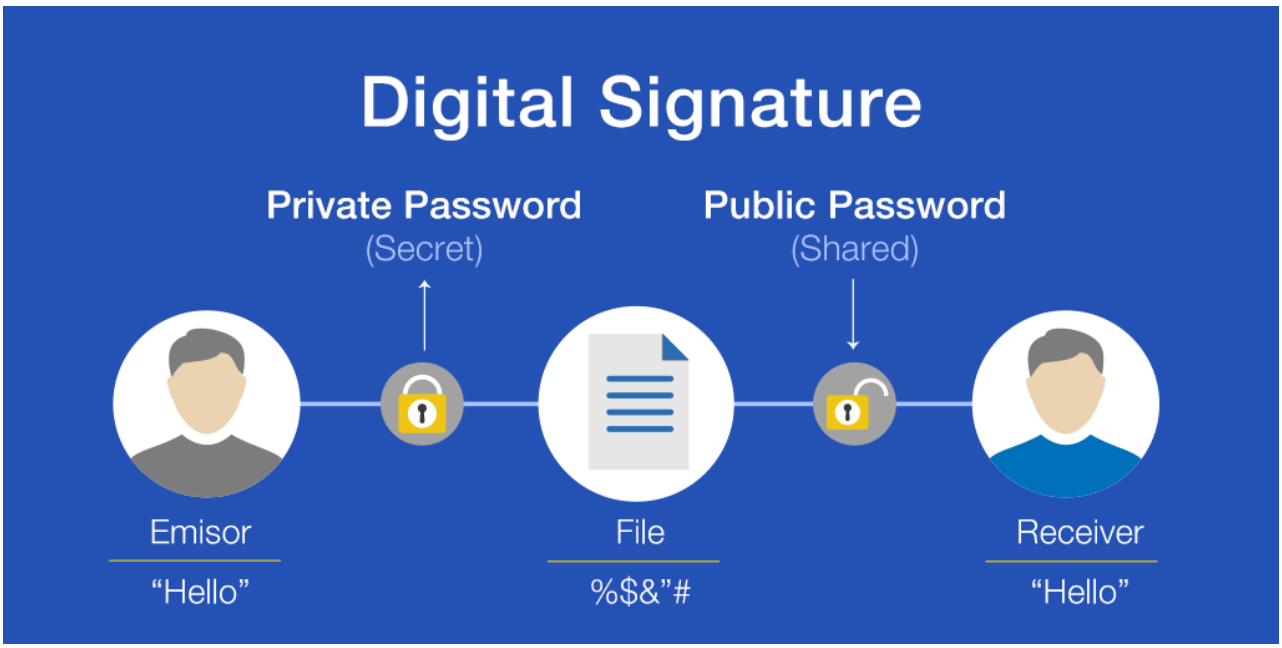
Digital signatures are like electronic "fingerprints." In the form of a coded message, the digital signature securely associates a signer with a document in a recorded transaction. Digital signatures use a standard, accepted format, called Public Key Infrastructure (PKI), to provide the highest levels of security and universal acceptance. They are a specific signature technology implementation of electronic signature (eSignature).

What is the difference between a digital signature and an electronic signature?

The broad category of electronic signatures (eSignatures) encompasses many types of electronic signatures. The category includes digital signatures, which are specific technology implementation of electronic signatures. Both digital signatures and other eSignature solutions allow you to sign documents and authenticate the signer. However, there are differences in purpose, technical implementation, geographical use, and legal and cultural acceptance of digital signatures versus other types of eSignatures.

In particular, the use of digital signature technology for eSignatures varies significantly between countries that follow open, technology-neutral eSignature laws, including the United States, United Kingdom, Canada, and Australia, and those that follow tiered eSignature models that prefer locally defined standards that are based on digital signature technology, including many countries in the European Union, South America, and Asia. In addition, some industries also support specific standards that are based on digital signature technology.

DR. V



How do digital signatures work?

Digital signatures, like handwritten signatures, are unique to each singer. Digital signature solution providers, such as DocuSign, follow a specific protocol, called PKI. PKI requires the provider to use a mathematical algorithm to generate two long numbers, called keys. One key is public, and one key is private.

Hashing?

- **Definition:** Hashing is the process of converting data (like a password or file) into a fixed-length string of characters using a mathematical function called a **hash function**.
- **One-way:** Hashing is *not reversible*. Once data is hashed, you cannot get the original input back.

Cipher?

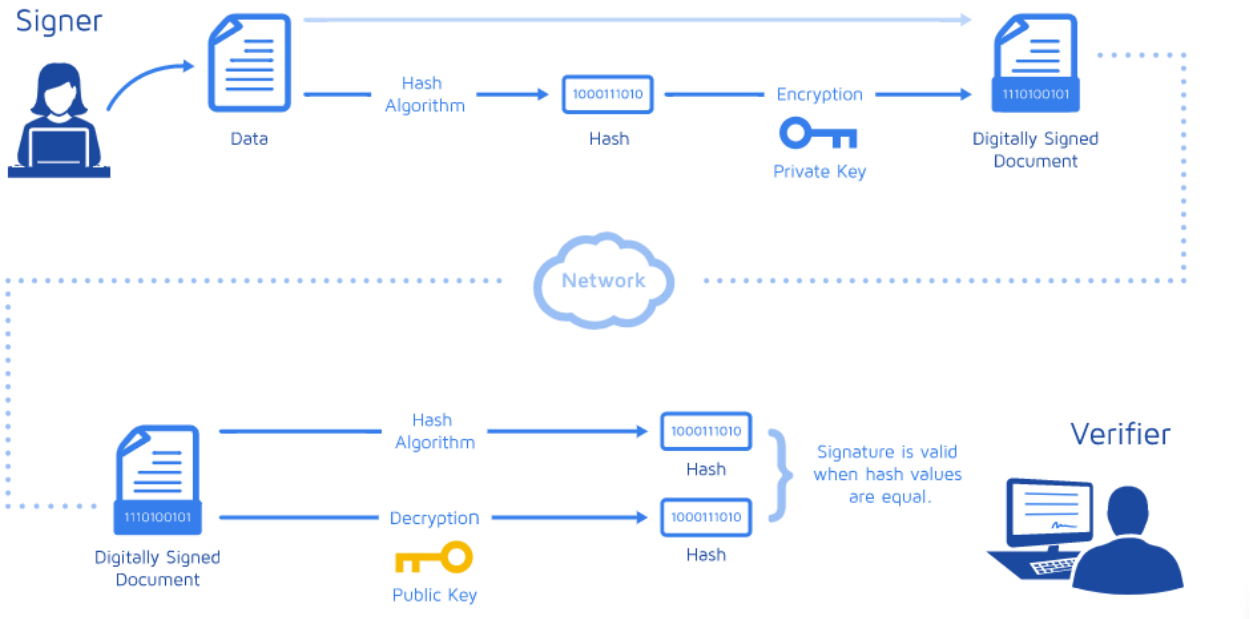
- A **cipher** is a method (or algorithm) used to **encrypt** and **decrypt** information.
- It takes readable data (called **plaintext**) and transforms it into unreadable data (called **ciphertext**) to protect it.

When a signer electronically signs a document, the signature is created using the signer's private key, which is always securely kept by the signer. The mathematical algorithm acts like a cipher,

creating data matching the signed document, called a hash, and encrypting that data. The resulting encrypted data is the digital signature. The signature is also marked with the time that the document was signed. If the document changes after signing, the digital signature is invalidated.

As an example, Jane signs an agreement to sell a timeshare using her private key. The buyer receives the document. The buyer who receives the document also receives a copy of Jane's public key. If the public key can't decrypt the signature (via the cipher from which the keys were created), it means the signature isn't Jane's or has been changed since it was signed. The signature is then considered invalid.

To protect the integrity of the signature, PKI requires that the keys be created, conducted, and saved in a secure manner, and often requires the services of a reliable Certificate Authority (CA). Digital signature providers, like DocuSign, meet PKI requirements for safe digital signing.



Create a digital signature?

eSignature providers, such as DocuSign, that offer solutions based on digital signature technology make it easy to digitally sign documents. They provide an interface for sending and signing documents online and work with the proper Certificate Authorities to provide trusted digital certificates.

Depending upon the Certificate Authority you are using, you may have to supply specific information. There also may be restrictions and limitations on whom you send documents to for signing and the order in which you send them. DocuSign's interface walks you through the process

and ensures that you meet all these requirements. When you receive a document for signing via email, you must authenticate as per the Certificate Authority's requirements and then "sign" the document by filling out a form online.

DR. VIRENDRA KUMAR TIWARI

FIREWALL

What is a Firewall?

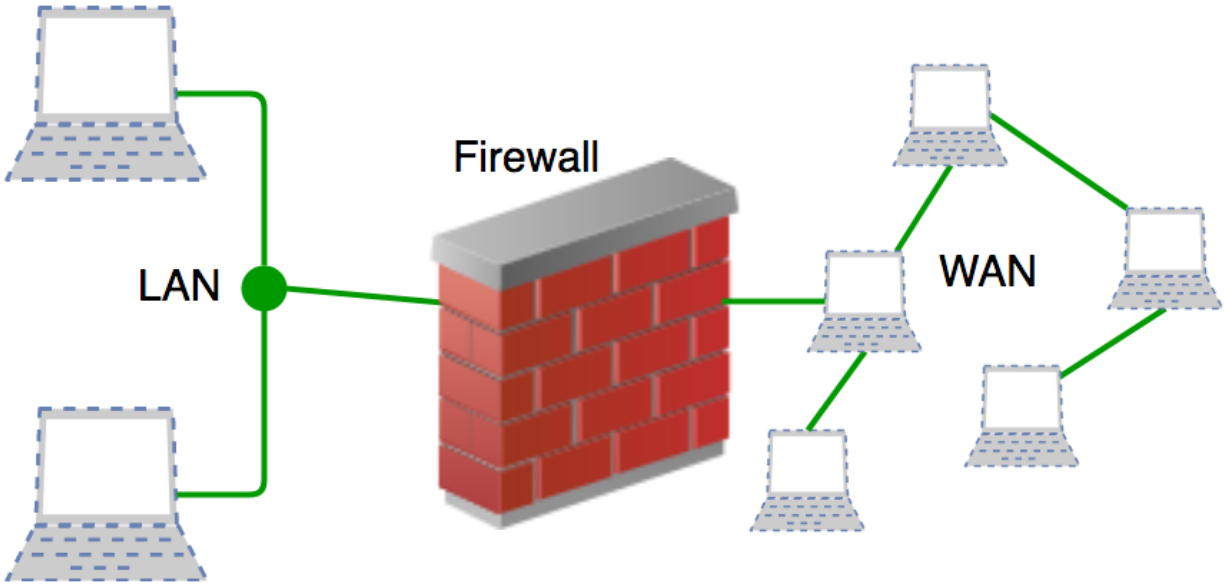
A Firewall is a security system to protect an internal network from unauthorized servers and networks based on predefined rules. It acts as a barrier and only allows the secured network to send or receive data.

How does a Firewall work?

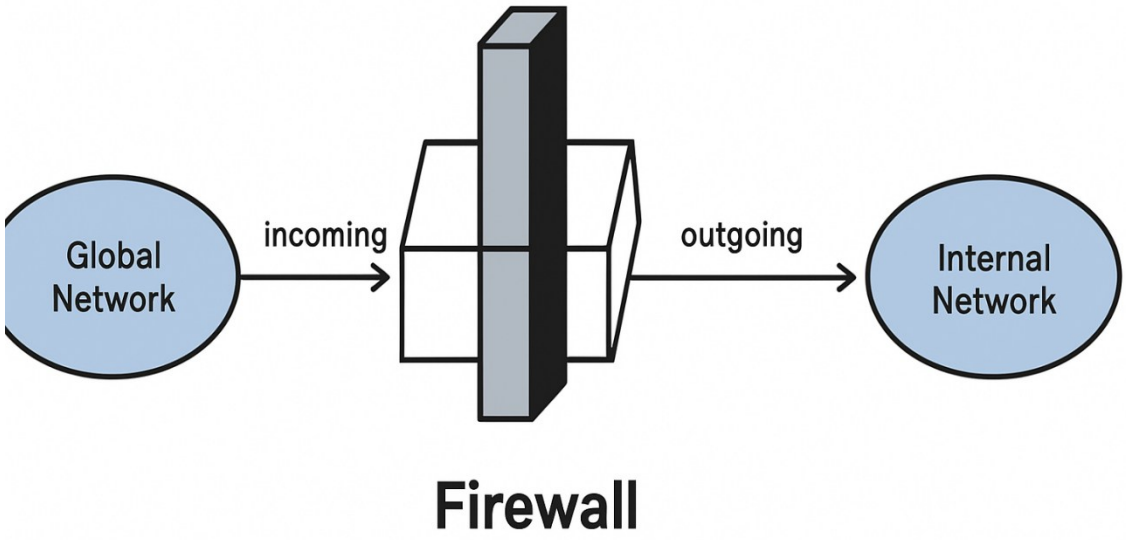
A Firewall analyses the network traffic and filters it so that the unsecured and suspicious networks cannot attack the system. The point where information is exchanged with an external network is called a port.

How is Firewall different from Antivirus?

A firewall is a security network designed to protect computer systems and networks from malicious attacks. Whereas Antivirus is a software utility program designed to protect a system from internal attacks from viruses.



A software firewall prevents unwanted access to the computer over a network connection by identifying and preventing communication over risky ports. Computers communicate over many different recognized ports, and the firewall will tend to permit these without prompting or alerting the user.



Firewall

History and Development of Firewall

Discussed below is a brief account of the evolution and development of Firewall and why it has become an important part of network security.

The term 'Firewall' meant a wall which intended to confine a fire within a line of adjacent buildings. It was only in the late 1980s when this was acknowledged as computer terminology.

It was during this time that the Internet started to emerge as a new tool for global use. Thus, having a means which could secure the transmission and flow of data was required by many.

Until the Firewall was introduced, routers performed the same function as it restricted the number of people who could use a particular network.

Types of Firewall

There are various types of Firewalls. Described below are each of them in detail for a better and simplistic understanding:

1. Packet Filtering Firewall

- One of the oldest types of Firewalls
- This type of Firewall creates a checkpoint at the traffic router. Only the secure and verified IP addresses or networks are allowed for the further flow of data

- The data packets are not verified, i.e. the information or data is not opened at the Firewall stage
- They are easy to use and do not overload the device and do not affect its processing or functioning speed

2. Application-Level Gateway Firewall

- It is also known as Proxy Firewall
- When the user connects with the destination server, it forms a connection with the application gateway
- The proxy then connects with the destination server and takes up the decision of forwarding the data packets
- It is a bit more secure in comparison to Packet Filtering Firewall
- Strong Memory and processors are required for using this Firewall

3. Circuit Level Gateway Firewall

- This works as the Sessions layer of the OSI Model
- Using this, two Transmission Control Protocol (TCP) connections can be set up together
- It can easily let the flow of data packets continue without consuming major computer resources
- These Firewalls are not much efficient as they do not check the data packets and incase a data packet comprises malware, it will allow it to pass if the TCP connections are successfully done

4. Stateful Inspection Firewall

- It is a combination of data packet inspection and TCP connection. Until both the fields are verified, the information cannot be approved
- They are less straining for computer resources
- However, they are a bit slow in comparison to other Firewalls

5. Next-Generation Firewall

- The recently launched Firewall systems are known as the Next-Gen Firewalls
- Under this, the data packets are also thoroughly checked before being passed on to the destination address
- These are still on the platform of improving and evolving and intend to use modern technology for automatic detection of errors and network safety

6. Software Firewall

- Any firewall which is installed in a local device, or a cloud server is called a Software Firewall
- They can be the most beneficial in terms of restricting the number of networks being connected to a single device and controlling the in-flow and out-flow of data packets
- Software Firewall also time-consuming

7. Hardware Firewall

- They are also known as Physical appliance based firewalls
- It ensures that the malicious data is stopped before it reaches the endpoint of the network at risk

a. Functions of Firewall

The following are the functions of a Firewall. Candidates can refer to these to apprehend the basic functions of a Firewall:

- Any data which enters or exits a computer network must pass through the Firewall
- All the valuable information stays intact if the data packets are securely passed through the Firewall
- Every time a data packet passed through a Firewall, it records it which allows the user to record the network activity
- No data can be modified as it is held securely within the data packets

Precisely, a Firewall ensures that all the data is secure and any malicious data trying to enter the internal network is not allowed to pass through.

A firewall can be simple or complex, depending on how specifically you want to control your Internet traffic. A simple firewall might require only that you configure the software in the router that connects your intranet to your ISP. A more complex firewall might be a computer running UNIX and specialized software.

Firewall systems fall into two categories

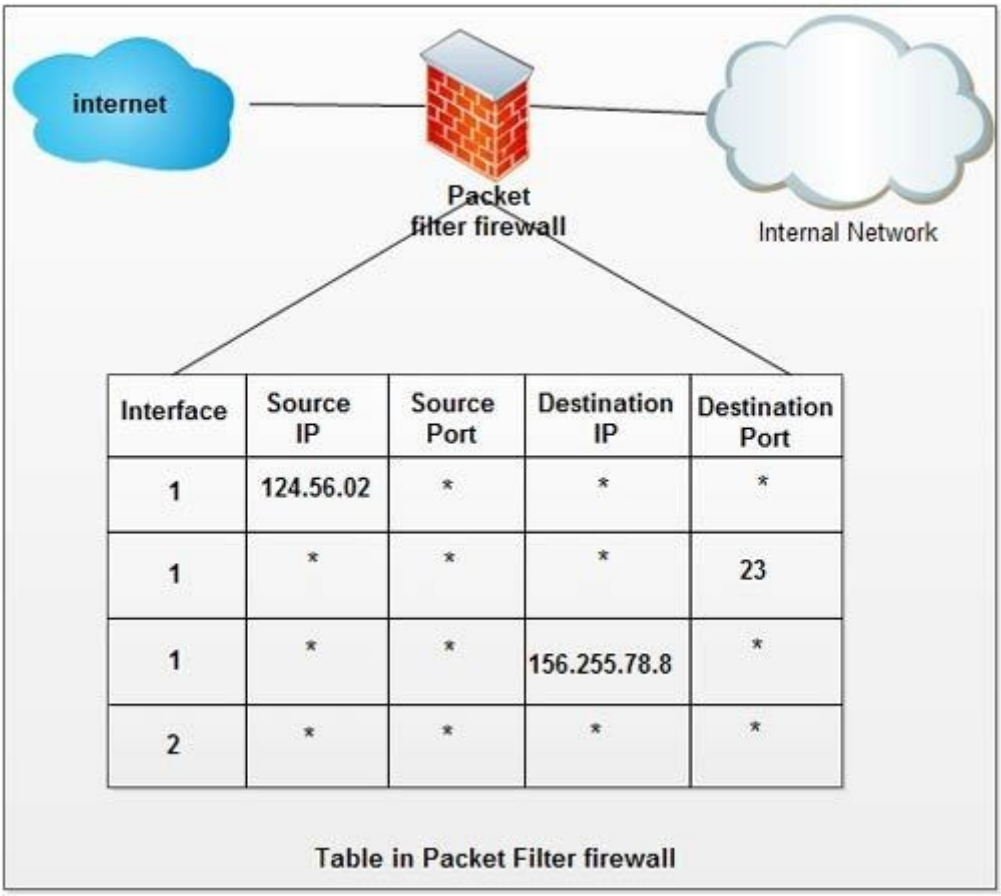
• Network-Level

• Application-Level.

b. *Network-Level Firewalls:*

It can be used as a packet filter. These firewalls examine only the headers of each packet of information passing to or from the Internet. The firewall accepts or rejects packets based on the packet's sender, receiver, and port. For example, the firewall might allow e-mail and Web packets to and from any computer on the intranet but allow telnet (remote login) packets to and from only selected computers.

Packet filter firewall maintains a filtering table that decides which packets are to be forwarded or discarded. A packet filter firewall filters at the network or transport layer.



Interface	Source IP	Source Port	Destination IP	Destination Port
1	124.56.02	*	*	*
1	*	*	*	23
1	*	*	156.255.78.8	*
2	*	*	*	*

Table in Packet Filter firewall

As shown in fig. the packets are filtered according to the following specifications:

1. Incoming packets from network 124.56.0.2 are block (* means any).
2. Incoming packets destined for any internal TELNET server (port 23) are blocked.
3. Incoming packets for internal host 156.255.7.8.8 are blocked.
4. Outgoing packets destined for an HTTP server (port 80) are blocked i.e. employees of organization are not allowed to browse the internet and cannot send any HTTP request.

c. Application-Level Firewalls:

These firewalls handle packets for each Internet service separately, usually by running a program called a *proxy server,* which accepts e-mail, Web, chat, newsgroup, and other packets from computers on the intranet, strips off the information that identifies the source of the packet and passes it along to the Internet.

When the replies return, the proxy server passes the replies to the computer that sent the original message. A proxy server can also log all the packets that pass by, so that you have a record of who has access to your intranet from the Internet, and vice versa.

USERS IDENTIFICATION AND AUTHENTICATION

User authentication verifies the identity of a user attempting to gain access to a network or computing resource by authorizing a human-to-machine transfer of credentials during interactions on a network to confirm a user's authenticity. The term contrasts with machine authentication, which is an automated authentication method that does not require user input.

Authentication helps ensure only authorized users can gain access to a system by preventing unauthorized users from gaining access and potentially damaging systems, stealing information or causing other problems. Almost all human-to-computer interactions -- other than guest and automatically logged-in accounts -- perform a user authentication. It authorizes access on both wired and wireless networks to enable access to networked and internet-connected systems and resources.

There is a growing demand for different types of user authentication technologies for both online and physical systems. The motivation to authenticate users ranges from access control reasons to business development purposes like adding e-commerce elements.

Organizations need to understand that passwords are not the only way to authenticate users. There is a wide variety of authentication technologies and an even greater range of activities that require authentication methods.

What Is Authentication?

Authentication is the process of identifying users that request access to a system, network, or device. Access control often determines user identity according to credentials like username and password. Other authentication technologies like biometrics and authentication apps are also used to authenticate user identity.

Why Is User Authentication Important?

User authentication is a method that keeps unauthorized users from accessing sensitive information. For example, User A only has access to relevant information and cannot see the sensitive information of User B.

Cybercriminals can gain access to a system and steal information when user authentication is not secure. The data breaches companies like Adobe, Equifax, and Yahoo faced are examples of what happens when organizations fail to secure their user authentication.

Hackers gained access to Yahoo user accounts to steal contacts, calendars and private emails between 2012 and 2016. The Equifax data breach in 2017 exposed credit card data of more than 147 million consumers. Without a secure authentication process, any organization could be at risk.

Common Authentication Types

Cybercriminals always improve their attacks. As a result, security teams are facing plenty of authentication-related challenges. This is why companies are starting to implement more

DR. VIRENDRA KUMAR TIWARI

sophisticated incident response strategies, including authentication as part of the process. The list below reviews some common authentication methods used to secure modern systems.

1. Password-based authentication

Passwords are the most common methods of authentication. Passwords can be in the form of a string of letters, numbers, or special characters. To protect yourself you need to create strong passwords that include a combination of all possible options.

However, passwords are prone to phishing attacks and bad hygiene that weakens effectiveness. An average person has about 25 different online accounts, but only 54% of users use different passwords across their accounts.

The truth is that there are a lot of passwords to remember. As a result, many people choose convenience over security. Most people use simple passwords instead of creating reliable passwords because they are easier to remember.

The bottom line is that passwords have a lot of weaknesses and are not sufficient in protecting online information. Hackers can easily guess user credentials by running through all possible combinations until they find a match.

2. Multi-factor authentication



Multi-Factor Authentication (MFA) is an authentication method that requires two or more independent ways to identify a user. Examples include codes generated from the user's smartphone, Captcha tests, fingerprints, voice biometrics or facial recognition.

DR. VIKAS KUMAR TIWARI

MFA authentication methods and technologies increase the confidence of users by adding multiple layers of security. MFA may be a good defense against most account hacks, but it has its own pitfalls. People may lose their phones or SIM cards and not be able to generate an authentication code.

3. Certificate-based authentication

Certificate-based authentication technologies identify users, machines or devices by using digital certificates. A digital certificate is an electronic document based on the idea of a driver's license or a passport.

The certificate contains the digital identity of a user including a public key, and the digital signature of a certification authority. Digital certificates prove the ownership of a public key and issued only by a certification authority.

Users provide their digital certificates when they sign in to a server. The server verifies the credibility of the digital signature and the certificate authority. The server then uses cryptography to confirm that the user has a correct private key associated with the certificate.

4. Biometric authentication

Biometrics authentication is a security process that relies on the unique biological characteristics of an individual. Here are key advantages of using biometric authentication technologies:

- Biological characteristics can be easily compared to authorized features saved in a database.
- Biometric authentication can control physical access when installed on gates and doors.
- You can add biometrics into your multi-factor authentication process.

Biometric authentication technologies are used by consumers, governments and private corporations including airports, military bases, and national borders. Technology is increasingly adopted due to the ability to achieve a high level of security without creating friction for the user. Common biometric authentication methods include:

- **Facial recognition**—matches the different face characteristics of an individual trying to gain access to an approved face stored in a database. Face recognition can be inconsistent when comparing faces at different angles or comparing people who look similar, like close relatives. Facial liveness like ID R&D's passive facial liveness prevents spoofing.
- **Fingerprint scanners**—match the unique patterns on an individual's fingerprints. Some new versions of fingerprint scanners can even assess the vascular patterns in people's fingers. Fingerprint scanners are currently the most popular biometric technology for everyday consumers, despite their frequent inaccuracies. This popularity can be attributed to iPhones.
- **Speaker Recognition**, also known as voice biometrics, examines a speaker's speech patterns for the formation of specific shapes and sound qualities. A voice-protected device usually relies on standardized words to identify users, just like a password.

DR. VIRENDRA KUMAR TIWARI

- **Eye scanners**—include technologies like iris recognition and retina scanners. Iris scanners project a bright light towards the eye and search for unique patterns in the colored ring around the pupil of the eye. The patterns are then compared to approved information stored in a database. Eye-based authentication may suffer inaccuracies if a person wears glasses or contact lenses.

5. Token-based authentication

Token-based authentication technologies enable users to enter their credentials once and receive a unique encrypted string of random characters in exchange. You can then use the token to access protected systems instead of entering your credentials all over again. The digital token proves that you already have access permission. Use cases of token-based authentication include RESTful APIs that are used by multiple frameworks and clients.

Authentication technology is always changing. Businesses must move beyond passwords and think of authentication as a means of enhancing user experience. Authentication methods like biometrics eliminate the need to remember long and complex passwords. As a result of enhanced authentication methods and technologies, attackers will not be able to exploit passwords, and a data breach will be prevented.

DR. VIRENDRA KUMAR TIWARI

SECURITY AWARENESS AND POLICIES, APPLICATION AREAS REQUIRING SECURITY

Information security notes mean leadership must protect corporate information, and the information of customers, associates, and employees, placed in their custody. Leadership's needs to ensure that every employee understands the corporate concern with the protection of information with a Information Security Policy.

An effective information protection program cannot be solely defined in terms of trust. Rather, it must be based upon the same prudent business practices that applied to earlier manual systems; careful definition of individual responsibilities, separation of controls, maintenance of audit trails, protection of vital records, and access to limited information, based on "need to know".

Information security notes include policies, procedures, controls, reviews, and especially, separation of duties. They must have real and continued management backing and involvement.

Management must be proactive regarding information security policy. They must let their people know the practices are important through example. They must take pride in their program. They must help bring about attitudinal changes in their people through strongly administered awareness programs, bringing about a clear understanding of the reasoning behind information security, instilling real concern about information protection, and instilling dissatisfaction with anything less than great execution.

Executive leadership must ensure and apprise newly appointed account management details of the information security policy.

Make each manager responsible not only for the protection and integrity of assets under their control, but also for compliance with Corporate Information Protection Policies and Procedures. Each manager must make the necessary risk management decisions that consider the unique environment in which their resources are used, and must be prepared to justify their decisions during an audit.

Policy Prologue (Policy)

Our company information is one of the most important assets, second only to its employees. Our company information includes all proprietary information, in any form, related to the business of our company that has been created using the resources of our company.

As our company competes in the global marketplace, it is very important that each employee understands the competitive value of our company information security notes and their responsibility to protect it. We must be able to demonstrate that it has exercised due diligence in protecting our company information. In this way we can successfully assert its rights to our company information through legal channels.

DR. VIJENDRA KUMAR TIWARI

This information security policy identifies the high-level guidance for Information Protection for all business entities of our company. It is based on the three sides of an Information Protection triangle where the three triangle legs consist of: Information Security, Business Continuity, and IT Compliance.

Information Protection Triangle

The **Information Security** leg consists of confidentiality and integrity. Confidentiality ensures that our company information is not disclosed to anyone who is not authorized to access it. Linked to this concept is the idea of "need-to-know", authorizing access only to those who can demonstrate a legitimate need for our information. Integrity ensures that information cannot be accidentally or intentionally modified or destroyed.

The **Business Continuity** leg consists of mitigation, crisis management, and contingency management. Mitigation deals with reducing or eliminating risks. Crisis management deals with the planning and training of people for the survival of our company team and the business entity following a disaster.

Contingency management deals with planning for the recovery and continuation of critical internal and customer business functions following a service interruption, and the testing of business recovery plans. This segment has also been known as availability in the past, but the scope is much broader today.

The **IT Compliance** leg consists of practices that do not fall within the scope of the other two legs. information security notes cannot be solely defined in terms of trust. Rather, it must be based upon the same prudent business practices that applied to earlier manual systems; careful definition of individual responsibilities, separation of controls, maintenance of audit trails, protection of vital records, and access to limited information, based on "need-to-know".

Included in the scope of the IT Compliance leg is adherence to the laws and ethics that govern us, i.e., copyright infringement, software licensing, export compliance, etc. These are controls, laws, or ethical principles, and are exactly what auditors look for, which is why the leg is called IT Compliance (being able to pass a stringent audit because the business is controlled, information is adequately protected, and laws are not being violated).

DR. VIRENDRA KUMAR TIWARI

Information Security Notes and Policy

The following identifies Information Protection requirements for our company

1. Information, in any form, relating to the business of our company, and created using the resources of our company, is an asset owned by our company. Our company information should be protected from unauthorized disclosure, modification, and destruction, whether intentional or unintentional.

2. All our company employees are collectively and individually responsible for protecting information. They must comply with the policy set forth in this document and any other

information protection documents derived from this policy. These include employee codes of conduct and other documents required as part of the terms of employment.

3. We mandate ongoing awareness and training activities to inform our employees of information protection issues are mandated as part of the ongoing support of information protection.

4. Our company information, when created, must be assessed according to its value and sensitivity to disclosure, and be managed according to "need-to-know". We identify controls that define our information security notes handling, retention, and destruction requirements.

5. Our company information must bear the legal and business marks as pertinent to communicate ownership, rights, and handling instructions. Some markings include, but are not limited to, the following: Copyright, Trademark, Patent, and the classification level.

6. Our company information cannot be released to the public through media interviews, publications, seminars, conversations, or in any other manner without a review procedure and management approval.

7. The computing and communication environment in which we create, process, store, and transmit information must be assessed as to the criticality of its existence and function relative to the business. Contingency management measures based on this assessment must be defined, implemented, maintained, and tested.

8. Systems and applications which process or communicate our company information must be created and maintained using a system development methodology that addresses the three sides of the Information Protection triangle, where the three sides consist of: Information Security, Business Continuity, and IT Compliance.

9. Our company and its employees comply with all legal requirements and all contractual agreements requiring information protection, e.g., copyright infringement, software licensing, patents, etc.

10. Our company and its employees should comply with the laws and regulations within each country where we conduct our business. This includes but is not limited to import and export regulations and the cross-border transfer of information and technology.

11. Our company and its employees should comply with our information retention requirements that support the business and support legal requirements.

12. Our company reserves the right to monitor and audit all activity and information security notes within the computer and communication resources utilized in support of our business. We may authorize a third party to exercise this right on behalf of our company.

13. Our company entities shall conduct an annual self-assessment regarding information protection controls, implementing corrective action where needed.

14. Suspicion or the occurrence of any fraudulent activity, unauthorized disclosure, modification, or destruction of our company information security notes and intrusions to the computing and communications environment must be reported to our company Security.

DR VIRENDRA KUMAR TIWARI

Physical Security

Environment

Data centers and computer rooms must have good physical security and strong protection from disaster and security threats, whether natural or caused by other reasons, to minimize the extent of loss and disruption.

Backup media containing essential business and/or mission critical information must be housed off-site at a safe distance from the main site in order to avoid damage arising from a disaster at the main site.

Equipment Security

All Information Systems must be placed in a secure environment or attended by staff to prevent unauthorized access.

Staff in possession of laptops, portable computer, personal digital assistant, or mobile computing devices for business purposes must safeguard the equipment in his/her possession, and must not leave the equipment unattended without proper security measures.

IT equipment must not be taken off the property without proper control.

Physical Access Control

- A list of people who are authorized to gain access to data centers, computer rooms or other areas supporting critical activities, where computer equipment and data are located or stored, must be kept up-to-date and be reviewed periodically.
- All access keys, cards, passwords, etc. for entry to any of the computer systems and networks must be physically secured or subject to well-defined and strictly enforced security procedures.
- All visitors to data centers or computer rooms must be always monitored by an authorized person.
- Automatic protection features (e.g. password protected screen saver, keyboard lock) in servers, computer terminals, workstations or microcomputers should be activated if there has been no activity for a predefined period to prevent an illegal system access attempt. Alternatively, the logon session and connection should be terminated. Also, user workstations should be switched off, if appropriate, before leaving work for the day or before a prolonged period of inactivity.
- All staff with separate personal offices that can be directly accessed from a public area and contain Information System(s) should lock the doors when these offices are not in use.

DR. VIRENDRA KUMAR TIWARI

- The display screen of an Information System on which classified information can be viewed must be carefully positioned so that unauthorized persons cannot readily shoulder-surf.

Access Control Security

Data Access Control

- Access to information must not be allowed unless authorized by the relevant information owner.
- Data access rights must be granted to users based on a need-to-know basis.
- Data access rights must be clearly defined and reviewed periodically.
- Access to an Information Security Notes System containing confidential or classified information must be restricted by means of logical access control.

Authentication

- Access to classified information security notes without appropriate authentication must not be allowed.
- Authentication must be performed in a manner commensurate with the sensitivity of the information to be accessed.
- Consecutive unsuccessful log-in attempts must be controlled.

Privacy

Management reserves the right to examine all information stored in or transmitted by company-owned computer systems.

User Identification

- Each user identity (user-ID) must uniquely identify only one user. Shared or group user-IDs are not permitted unless explicitly approved by the IT Security Officer.
- Users are responsible for all activities performed with their user-IDs.

User Privileges Management

- All accounts must be revoked after a pre-defined period of inactivity.
- User privileges must be reviewed periodically.
- At the time that a member of the staff is transferred or ceases to provide services to the company, all related Information Systems privileges must be promptly terminated.
- The use of special privileges must be restricted and controlled.

Password Management

- Business entities must define a strict password policy that details at least, minimum password length, initial assignment, restricted words and format, password life cycle, and include guidelines on suitable system and user password selection.

DR. VIRENDRA KUMAR TIWARI

- Passwords must not be shared or divulged unless necessary (e.g., helpdesk assistance, shared PC and shared files). The risk of sharing passwords is that it increases the probability of security being compromised. If passwords must be shared, explicit approval from the IT Security Officer must be obtained. In addition, the shared passwords should be changed promptly when the need no longer exists and should be changed frequently if sharing is required on a regular basis.

- Passwords must always be well protected when held in storage. Passwords must be encrypted when transmitted over an un-trusted communication network. Compensating controls must be applied to reduce the risk exposure of Information Systems to an acceptable level if encryption is not available.

- Staff are prohibited from capturing or otherwise obtaining passwords, decryption keys, or any other access control mechanism, which could permit unauthorized access.

- All vendor-supplied default passwords must be changed before any Information System is put into operation.

- All passwords must be promptly changed if they are suspected of being compromised or disclosed to vendors for maintenance and support.

Network Access Control

Prior approval from the IT Security Officer is required to connect an Information System with another Information System under the control of another entity. The security level of the Information Security Notes System being connected must not be downgraded.

Logging

- Business entities must define policies relating to the logging of activities of Information Security Notes Systems under their control according to the business needs and data classification.

- Any log kept must provide sufficient information to support comprehensive audits of the effectiveness of, and compliance of information security notes measures.

- Logs must be retained for a period commensurate with their usefulness as an audit tool. During this period, such logs must be secured such that they cannot be modified and can only be read by authorized people.

- Logs must not be used to profile the activity of a particular user unless it relates to a necessary audit activity supported by the IT Security Officer.

- Regular checking on log records, especially on system/application where classified information is processed/stored, must be performed, not only on the completeness but also the integrity of the log records. All system and application errors which are suspected to be triggered because of security breaches must be reported and logged.

- Clock synchronization should be configured to keep the clocks of Information Security Notes Systems in sync.

DR. VIRENDRA KUMAR TIWARI

Data Security

Overall Data Confidentiality

- Information security notes that may compromise the security of those systems must not be disclosed to users, or any other third parties, except on a need-to-know basis and only if authorized by the IT Security Officer.
- Staff must not disclose information about the individuals, business entities or specific information security notes systems that have suffered from damages caused by computer crimes and computer abuses, or the specific methods used to exploit certain system vulnerabilities, to any people other than those who are handling the incident and responsible for the security of such systems, or authorized investigators involved in the investigation of the crime or abuse.
- Staff must not disclose to any unauthorized persons the nature and location of the Information Systems, and the information security notes that are in use or the way in which they are implemented.
- All stored information classified as confidential or above must be encrypted.
- Business entities must comply with handling in relation to Information Security notes security including, but not limited to, storage, transmission, processing, and destruction of classified information.

Information Backup

- Backup and recovery procedures must be well documented, properly implemented, and tested periodically.
- Backups must be carried out at regular intervals.
- Backup activities must be reviewed regularly.
- Backups must be stored off-site at a remote distance from the main site and be protected. Backup media should also be protected against unauthorized access, misuse, or corruption during transportation.

DR. VIRENDRA KUMAR TIWARI

Application Security

Application Development & Maintenance

- Application development staff must include information security notes planning and implement the appropriate information security notes measures and controls for systems under development according to the systems' security requirements.

- Documentation and listings of applications must be properly maintained and restricted on a need-to-know basis.
- Formal testing and review of the information security notes controls must be performed prior to implementation.
- The integrity of an application must be maintained with appropriate security controls such as version control mechanisms and separation of environments for development, system testing, acceptance testing, and live operation.
- Application development staff must not be permitted to access production information unless necessary.

Configuration Management & Control

- Change control procedures for requesting and approving program/system changes must be documented.
- Changes affecting existing information security notes protection mechanisms must be carefully considered.
- The installation of all computer equipment and software must be done under control and audit.
- Business entities must ensure that staff are formally advised of the impact of security changes and usage on Information Systems.

Network & Communication Security

General Network Protection

- Internal network addresses, configurations and related system or network information must not be publicly released without the approval of the concerned entity.
- All internal networks with connections to other networks or publicly accessible computer networks must be properly protected.
- Security measures must be in place to prevent unauthorized remote access to the systems and data.
- Staff are prohibited from connecting workstations to an external network by means of any communication device, such as dial-up modem, wireless interface, or broadband link, if the workstations are simultaneously connected to a local area network (LAN) or another internal communication network, without the approval of the entity concerned.
- Staff must not connect any unauthorized Information System device to an Information System without prior approval as designated by the entity.
- Proper configuration and administration of information / communication systems is required and must be reviewed regularly.

DR. VIRENDRA KUMAR TIWARI

- Connections and links made to other networks must not compromise the security notes processed at another, and vice versa.
- Confidential/Restricted information security notes must be encrypted when transmitted over an un-trusted communication network.
- Top Secret/Secret information must be transmitted only under encryption and inside an isolated LAN approved by the IT Security Officer.

Internet Security

- All Internet access must be either through centrally arranged Internet gateways or the entities own Internet gateway conforming to internal security standards. In circumstances where this is not feasible or having regard to the mode of use, i.e., such modes of use may include, for example, Internet surfing, email exchange, and the use of official, portable computers while on business. The relevant standalone machines must still be protected by any applicable security mechanisms.
- Business entities may consider allowing Internet access through stand-alone machines, if there is an approval and control mechanism at an appropriate level within the business entity.
- Business entities should consider the value versus inconvenience of implementing technologies to blocking non-business web sites. The ability to connect with a specific web site does not in itself imply that users of systems are permitted to visit that site.
- Each entity must clearly define and communicate to users its internet policy in relation to acceptable Internet usage.
- All software and files downloaded from the Internet must be screened and verified with anti-virus software.
- Staff should not execute mobile code or software downloaded from the Internet unless the code is from a known and trusted source.

Email Security

- Each entity must clearly define and communicate to users its email policy in relation to acceptable email usage.
- Systems administrators must establish and maintain a systematic information security notes process for the recording, retention, and destruction of electronic mail messages and accompanying logs.
- Incoming/outgoing email must be screened for computer viruses and malicious codes.
- Internal email address lists containing entries for authorized users must be properly maintained and protected from unauthorized access and modification.

DR VIRENDRA KUMAR TIWARI

- Email transmission of classified information must be transmitted only on an Information System approved by the IT Security Officer.
- Emails from suspicious sources should not be opened or forwarded.

Protection Against Computer Virus and Malicious Code

- Anti-virus software must always be enabled on all local area network servers and personal computers, and computers connecting to the internal network via remote access.
- Business entities must protect their Information Security Notes Systems from computer viruses and malicious codes. Virus signatures, malicious code definitions as well as their detection and repair engines must be updated regularly and whenever necessary.
- Storage media and files from unknown source or origin must not be used unless the storage media and files have been checked and cleaned for computer viruses and malicious codes.
- Users must not intentionally write, generate, copy, propagate, execute or be involved in introducing computer viruses or malicious codes.
- Business entities must implement proper measures to protect their wireless or mobile computing devices against computer viruses and malicious codes.

Software and Patch Management

- Computers and networks must only run software that comes from trustworthy sources.
- No unauthorized application software must be loaded onto an Information System without prior approval from the IT Security Officer as designated by the entity.
- Business entities must protect their Information Security Notes Systems from known vulnerabilities by applying the latest security patches recommended by the product vendors or implementing other compensating security measures.
- Before security patches are applied, proper risk evaluation and testing should be conducted to minimize undesirable effects to Information Systems.

Wireless Security

- Business entities must document, monitor, and control wireless networks with connection to internal networks.
- Proper authentication and encryption security controls must be employed to protect data communication over wireless networks with connection to internal networks.

Security Risk Assessments & Audits

DR. VIRENDRA KUMAR TIWARI

Security Assessment

- Information security notes risk assessments for information systems and production applications must be performed at least once every two years. A security risk assessment must also be carried out prior to major enhancements and changes associated with these systems or applications.
- Use of software and programs for security risk assessment analysis must be restricted and controlled.

Security Auditing

- Information Systems must be periodically evaluated by auditors of an independent and trusted party to determine the minimum set of controls required to reduce risk to an acceptable level.
- Auditing compliance of computer and network security policies must be performed periodically.
- Use of software and programs for security audit analysis must be restricted and controlled.

Security Incident Management

Security Incident Monitoring

- Business entities must establish an incident detection and monitoring mechanism to detect, contain and ultimately prevent security incidents.
- Business entities must ensure that system logs and other supporting information are retained for the proof and tracing of security incidents.

Security Incident Response

- Business entities must establish, document and maintain a security incident handling/reporting procedure for their Information Systems.
- Staff must be made aware of the security incident handling/reporting procedure that is in place and must observe and follow it accordingly.
- All network or systems software malfunctions, information security alerts, warnings, suspected vulnerabilities, and the like, and suspected network security problems, must be reported immediately only to the responsible party according to the incident handling procedure.
- Immediate follow-up actions are required on suspected system intrusion according to security incident handling/reporting procedures.

DR. VIRENDRA KUMAR TIWARI

MOBILE COMMERCE: INTRODUCTION, GROWTH, SUCCESS STORIES OF MOBILE COMMERCE, TECHNOLOGIES FOR MOBILE COMMERCE, M-COMMERCE IN INDIA, DIGITAL MARKETING.

M-Commerce, short for Mobile Commerce, is a branch of commerce that deals with the **digital transactions** made from the smartphone. It doesn't require physical contact between two people for sending or receiving the money.



In other words, we can say that **M-commerce** (mobile commerce) is the buying and selling of goods and services through wireless handheld devices such as smartphones and tablets. As a form of e-commerce, m-commerce enables users to access online shopping platforms without needing to use a desktop computer.

Examples of M-commerce –

- In-app purchasing
- Mobile banking
- Virtual marketplace apps like the Amazon mobile app or a digital wallet such as **Apple Pay, Android Pay, and Samsung Pay.**
- Mobile ticketing

According to Wikipedia, *the term* **mobile commerce** *was originally coined in 1997 by Kevin Duffey at the launch of the Global Mobile Commerce Forum, to mean "the delivery of electronic commerce capabilities directly into the consumer's hand, anywhere, via wireless technology."*

Types of M-Commerce

M-commerce can be categorized by function as either mobile shopping, mobile banking or mobile payments. Mobile shopping allows for a customer to purchase a product from a mobile device, using an application such as Amazon, or over a web app.

A subcategory of mobile shopping is app commerce, which is a transaction that takes place over a **native app**. Mobile banking includes any handheld technology that enables customers to conduct transactions.

This is typically done through a secure, dedicated app provided by the banking institution. Mobile payments enable users to buy products using a mobile device. Digital wallets, such as Apple Pay, allow a customer to buy a product without needing to swipe a card or pay with physical cash.

M-Commerce is a vast field which doesn't end at buying a commodity online- it includes all the behaviors related to checking any stuff online from your smartphone.

The different types of Mobile Commerce are-

1. **Browsing for stuff online on your mobile** – This type deals with surfing for stuff online like looking for Groceries, Daily essentials, and electronics. We're talking about dedicated apps, optimized websites, or even social media platforms like Facebook or Instagram that allow in-app purchases or linking to online stores.

2. **Purchasing app-delivery stuff** (Food delivery or e-commerce apps) – This type deals with the services related to ordering things like food, cab pickup, and others.

3. **Mobile banking** – Mobile banking is the method that involves accessing the features of the bank using online methods. The transactions are made from specific apps designed by apps, though some financial services companies are now experimenting with chatbots or messaging apps to deliver customer service.

4. **Mobile App payments(Google Pay or PayPal)** – This type primarily focuses on making payment transactions through apps. The user is required to register their credit or debit card and then use it whenever they want.

5. **Purchasing or renting digital content (Netflix, Spotify, etc) on a mobile device** – This involves buying or renting online services like Music Streaming, Video Streaming, or commodity-based on a rent basis.

6. **Mobile person-to-person payments(Venmo or Xoom)** – This type involves sending money from one person to another, be it for buying stuff or sending it to someone in need. This type of transaction can be made by sending money to someone's number or to their bank account directly.

How Mobile Commerce Works?



With most **m-commerce** enabled platforms, the mobile device is connected to a wireless network that can be used to make online product purchases. For those in charge of developing an M-commerce application, important ***KPIs*** to monitor include the *total mobile traffic, the total amount of traffic on the application, average order value, and the value of orders over time.*

Similarly, tracking the mobile add to cart rate will help developers examine, if visitors are becoming customers. M-commerce developers may also be interested in logging *average page loading times, mobile cart conversion rates and SMS subscriptions.*

In terms of mobile payment products, they operate through a form of peer-to-peer (P2P) sharing. Once a mobile device is paired with a bank card's information, the phone can be waved over a payment terminal to pay for a product. This contact less payment via a mobile device is feasible due to the use of Near Field Communication(NFC).

Applications of Mobile Commerce-

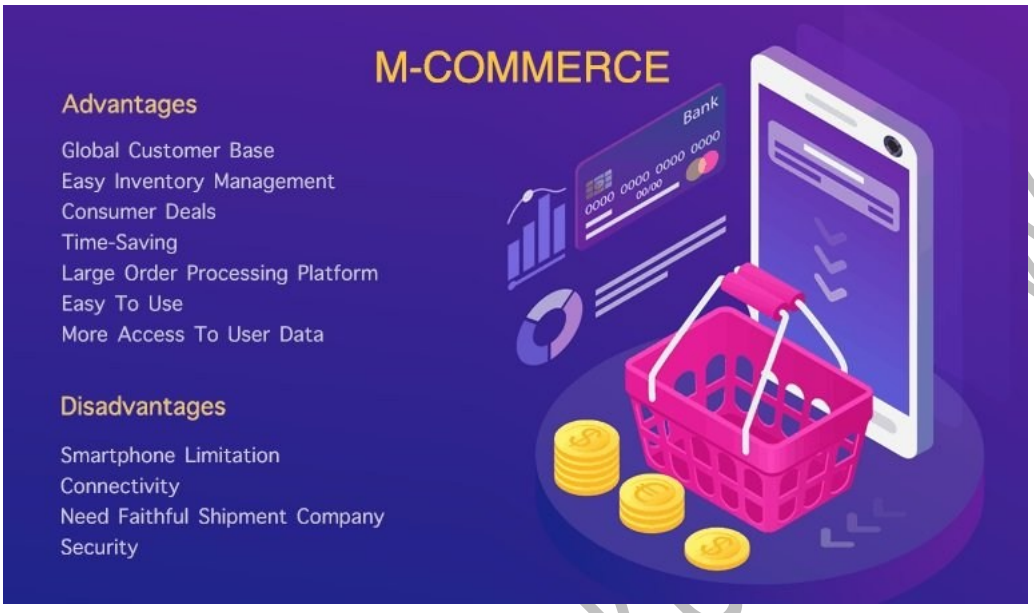
Mobile commerce has entered into all spheres of our daily lives like- finance, retail, telecommunication, healthcare, information technology, sales and services. Need for M-commerce has increased multi-fold in recent times because of the ease of functioning and accessibility they offer.

Some of the applications of mobile commerce are-

1. M-Commerce for finance
2. M-Commerce for Retail and After sale Services
3. M-commerce & Mobile ticketing
4. M-commerce & Mobile marketing
5. M-commerce for mobile entertainment
6. M-commerce for hotel reservations
7. M-commerce for Healthcare & Medicine

8. M-commerce for Information
9. M-commerce for Gaming
10. M-commerce for Intra-office communication

Advantages of M-Commerce



Advantages of M-Commerce are-

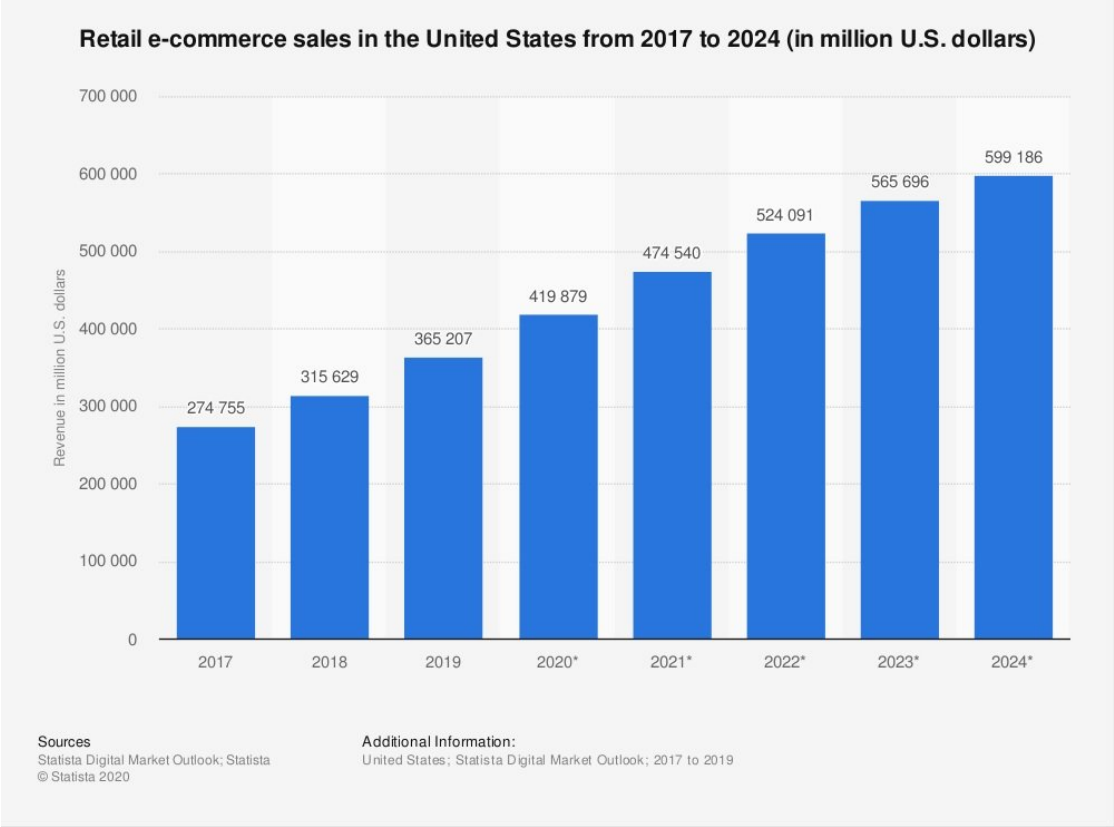
1. Increases the amount of customer retention by being easily accessible to them
2. Wider variety of commodities and services
3. More options for selecting the product
4. Convenient for the consumer to compare the pricing, product reviews, and making purchases without the use of a computer.
5. Multiple options for payments like the credit card and debit card payments,
6. Better user experience

Disadvantages of M-Commerce are-

1. The technology required to set up M-commerce at the moment is very expensive. The initial cost to **begin a business** is very high.
2. In developing countries, the network signal is not very good and the providers are not capable of providing good speed. Due to this, it is not suitable for data transfer.
3. There is a risk of security- Although it is quite safe these days, there is always a chance of data leaking and intrusions.
4. A poorly designed app can lead to lesser number of purchases because of customer dissatisfaction.
5. Mobile payment is still not available across many locations in the world.

Future scope of M-Commerce

M-Commerce is rapidly expanding in today's time. Everyone is busy and they don't have the time or energy to go to the market and buy stuff for them. Instead, they prefer ordering from their home itself. The biggest trend for M-Commerce is its market share/ growth. **M-Commerce** spending in 2018 was calculated at $501 Billion and it is expected to grow more to $740 Billion by 2023.



Major Trends for M-Commerce indicating Great Future Scope-

1. **The mobile wallet market will grow to $5.3 trillion by the end of 2020** – Mobile wallets have made our life easier by reducing the hassle of carrying a wallet with us everywhere. It offers the convenience of making as many transactions we want by just storing our credit or debit card details just once. A proof of this trend is the fact that the market size of mobile wallets has grown from *$1.65 Trillion to $5.3 Trillion* between 2013 and 2020.
2. **M-Commerce market will see new contenders between 2020 and 2025** – Currently, the payment markets are captured by old players like PayPal, Google, Apple, and SAP. But in the coming years, you can see the increase in the number of new contenders capturing the majority amount of market share. They will bring more opportunities for customers and share the market share more uniformly.
3. **The mobile commerce revenue is expected to hit $3.56 Trillion by 2021** – The revenue generated has been increasing with each passing year and will touch $3.56 trillion by 2021. This is proof of the increasing demand for mobile-based shopping.

M-Commerce Key Statistics & Insights-

To help you understand the potential of mobile commerce, check these insights and key statistics:

- 96% of Americans own a cellphone.
- 8 out of 10 Americans shop on their Mobile devices.
- Mobile commerce is expected to outgrow non-mobile commerce in 2021.
- Mobile digital advertising spend is double that of desktop advertising spend—$71 billion was spent on mobile advertising in 2018, while only $37 billion was spent on desktop.
- On Black Friday of 2018, 66% of shopping was done on mobile devices.
- In 2021, mobile commerce sales will account for more than half of total e-commerce sales.
- Today, one-third of purchasing decisions is influenced by researching products on mobile devices.
- More than half of retailers already have a mobile app and over 50% of the rest is going to build one soon.
- In mid-2019, mobile e-commerce spending in the United States reached a smashing $41.2 billion.
- The total number of US-based shoppers who make mobile purchases will reach 168.7 million.
- The volume of mobile commerce sales will be more than double between 2017 and 2020, reaching $ 336 billion this year.

What is the Scope of Mobile Commerce in India?

In India, the majority of the people, irrespective of their ages, are using a smartphone. Especially during the coronavirus pandemic, the few people who didn't use a smartphone probably started using one. From children in their nappies to grannies in their chairs are using a smartphone for multiple reasons. On average, the age group between 25 and 34 are using these smartphones to shop online. The m-commerce niche is to be completely explored and utilized in its full potential and India is actively working in that regard. Following are a few initiatives taken by the Government of India in order to encourage m-commerce:

1. Unified Payment Interface
2. GST Implementation
3. Mobile Wallets
4. The Digital India Makeover
5. Startup India
6. Skill India

Digital Marketing

Digital Marketing is the use of social media, the internet, mobile devices, and other channels to reach customers. It is a broad field that includes techniques about how to attract customers via email, content marketing, search platforms, social media, and more. Digital Marketing basically targets a specific segment of the customer base and includes search results ads, email ads, and promoted tweets.- anything that incorporates marketing with customer feedback or a two-way interaction between the company and customer.

In the past few years, there is a lot of change in the ways people do shopping. Now, people mostly prefer to shop online, and also during this COVID-19 pandemic, the eCommerce industry is on a verge of a boom. Customers can just scroll through their smartphones and can get access to millions of products which include almost everything whether it is new mobile phone sales, or fashion sales, gadgets, anything you like. Many things are only releasing their products on online platforms only. You all must be well aware of Flipkart's Big Billion Sale, Amazon festival sale, and many more.

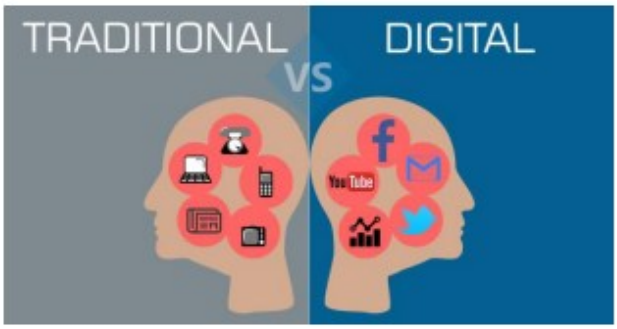
- The days of browsing at a physical store location and asking sales associates for more information about products are gone. Now, consumers use the internet to get the information they need to make an informed purchasing decision, even if they still visit the physical store location to make their final purchase.
- The basic aim of both online marketing and offline marketing is to reach a maximum number of customers and also target specific customers.
- It takes more time and money to promote offline marketing whereas it becomes easy and cheap (comparable) to promote with the help of digital marketing and reach out to the world.

DR. VIRENDRA KUMAR

Traditional Marketing Vs Digital Marketing:

The debate continues as to whether digital marketing is overpowering and surpassing traditional marketing or not. Many think that for the most part, digital marketing has taken over and traditional marking barely exists, if at all. Recent occurrences such as the magazine giant, Newsweek switching to totally digital publications cause ripples throughout the marketing arena. Over the last year or so traditional marketing had fallen nearly 160% while in the same time frame

expenses for digital marketing increased over 14%.



Traditional Marketing:

The traditional way of marketing lets businesses market their products or administrations on print media, radio and TV commercials, bill boards, business cards, and in numerous other comparable ways where Internet or web-based social networking sites were not utilized for promoting.



▪ However, traditional promoting approaches had constrained client reachability and extent of driving clients' purchasing conduct. In addition, traditional marketing methods were not quantifiable too.

▪ There are many facets of traditional marketing and examples might include tangible items such as business cards, print ads in newspapers or magazines. It can also include posters, commercials on TV and radio, billboards and brochures. Traditional marketing is anything except digital means to brand your product or logo.

▪ Another overlooked means of traditional marketing is when people find a particular business through a referral or a network and eventually you build a rapport with them.

▪ Because of its longevity, people are accustomed to traditional marketing. Finding ads in magazines and newspapers, or reading billboards are still familiar activities and people still do them all the time.

▪ Most of the time, traditional marketing is reaching only a local audience even though it is not limited to one.

▪ There are some aspects where traditional marketing wins over the online advertising battle, which include Target Local Audience, Materials are for keeps, More personal and Simpler process.

▪ One of the primary disadvantages of traditional marketing is that the results are not easily measured, and in many cases cannot be measured at all.

In most cases, traditional marketing is also more costly than digital marketing. And perhaps the biggest disadvantage today is that traditional marketing is static which means there is no way to interact with the audience. It's more like you are throwing information in front of people and hoping that they decide to take action.

Digital Marketing:

Digital Marketing can be understood as a well-targeted, conversion-oriented, quantifiable, and interactive marketing of products or services by utilizing digital innovation to achieve the customers, and transform them into clients in a sustainable fashion. The whole concept and functionalities of Digital Marketing are more competent, effective, result-oriented and measurable, which make it very different from traditional marketing



VIDYA KUMAR TIWARI

▪ Digital or online marketing is the marketing mode of the global village. It is only obvious that the era of the internet will have its influence in every realm of life.

▪ The world of digital marketing continues to evolve and as long as technology continues to advance, digital marketing will as well.

▪ Examples of digital marketing include things like websites, social media mentions, YouTube videos, and banner ads. Specifically, digital marketing is similar to traditional advertising, but using digital devices.

▪ However, digital marketing is considered a form of inbound marketing and its goal is for people to find you. Businesses put content (or ads) out for individuals to find.

▪ People may conduct an organic online search, a paid search, find your business on a social network or by reading content that has been published online such as a blog or an article. The more they see you or your content, the more familiar they will become with your brand and they will eventually develop a trust and a rapport with you through this online presence.

▪ One benefit to using digital marketing is that the results are much easier to measure; and another is that a digital campaign can reach an infinite audience. It is also possible to tailor a digital campaign to reach a local audience but it can also be used on the web and reach the entire globe when appropriate.

▪ Digital marketing is also a very interactive means of reaching an audience since it makes use of social outlets. There can be plenty of direct contact between the audience and the business which means that the business can get some very valuable consumer feedback.

▪ Benefits of Digital Marketing over Traditional Marketing include reduced cost, real time result, brand Development, non-intrusive, higher exposure, higher engagement, Quicker publicity, Non interruptive, Good For All Stages Of Fields, Easy analytics and Strategy Refinement.

▪ One of the disadvantages to using digital media marketing strategies is that it can take some time to realize measurable success.

DR. VIRENDRA KUMAR TIWARI

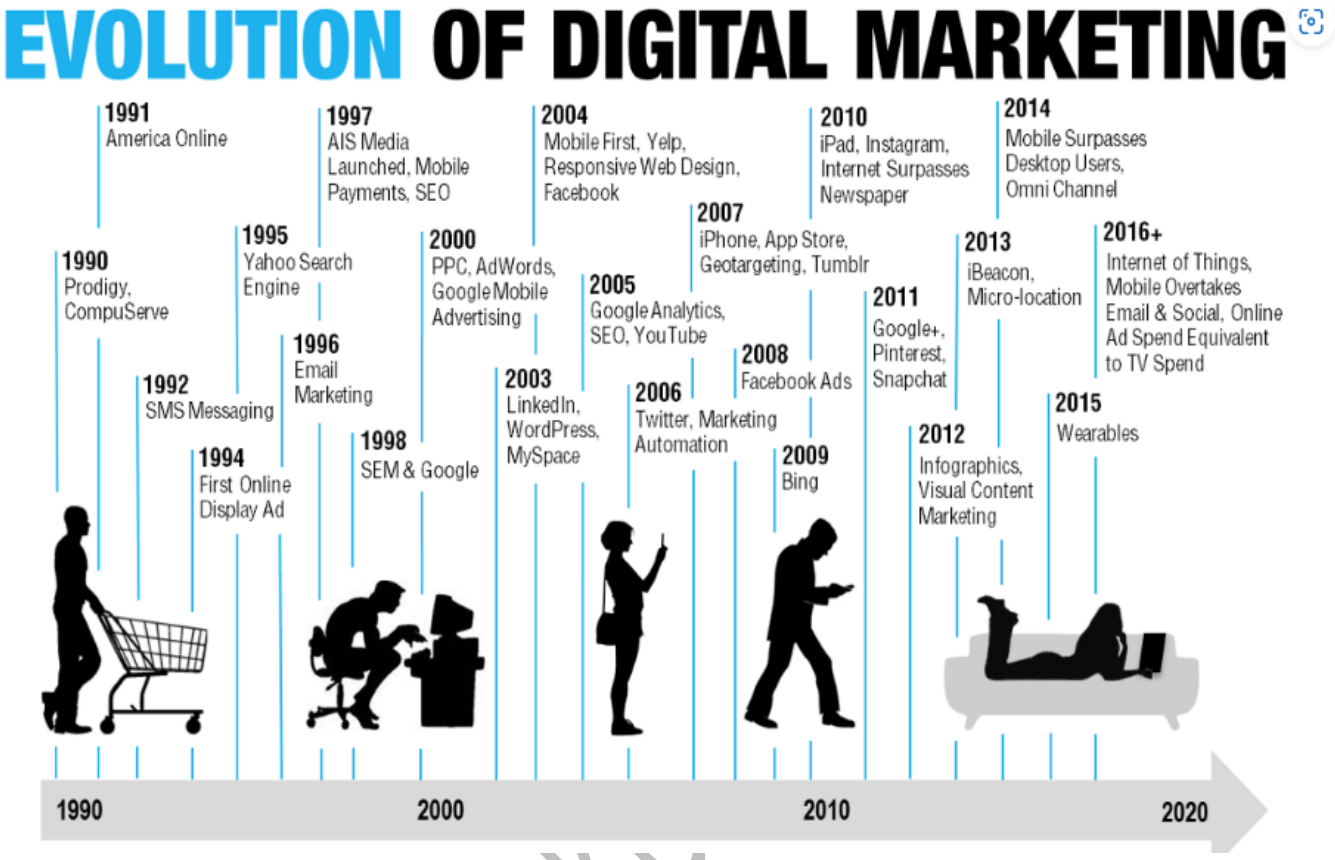
Differences between Traditional Marketing & Digital Marketing:

Traditional Marketing	Digital Marketing
1. Communication is unidirectional in traditional marketing, which means, an organization communicates about its services with its audiences.	1. Communication is bidirectional in Digital Marketing as businesses can communicate with customers and customers can ask queries or make suggestions to businesses as well.
2. Medium of communication in traditional marketing is generally phone calls, emails, and letters.	2. Medium of communication is more powerful and involves social media websites, chats, apps and Email.
3. Campaign in Traditional marketing takes more time as designing, preparing, and launching are involved.	3. Digital marketing campaigns can be developed quite rapidly and with digital tools, channelizing Digital Marketing campaigns is easier.
4. It is best for reaching local audience.	4. It is very effective for reaching global audiences.
5. It is almost impossible to measure the effectiveness of a traditional marketing campaign.	5. Digital Marketing lets you measure the effectiveness of a digital marketing campaign through analytics.

History of Digital Marketing

Digital marketing is not new. It's been around since the Internet started. Now digital marketing is becoming popular due to the increase in internet users, mobile phone users and digital content consumption.

DR. VIRE



Actually, digital marketing was first known as internet marketing and online marketing. In those early days of the internet, mainly the internet was used for communication via email and websites and SEO was used for online advertising and marketing.

When social media platforms like Facebook, Instagram became popular, video platforms like YouTube became popular and people started using mobiles and companies started using websites, social media and videos etc for marketing. This is how digital marketing was started and became popular as an umbrella term.

Why Digital Marketing is Important?

- In the time when there were no smartphones, then companies used T.V, magazines, radio, newspapers for advertising their products and thus if any customer is interested in their product they will reach them automatically by having a glimpse of their advertisement whereas now in this era of smartphones, maximum people spend their maximum time on a smartphone, on various social media platforms like Instagram, Youtube, Facebook, Whatsapp, Twitter, etc.
- How much time do you spend on your Phone in a day(Average)? Comment in the comment box
- Instead of radio, people listen to songs on platforms like Gaana, Saavan, Wynk Music, etc, instead of reading newspapers people are reading blogs, and in spite of watching T.V, they

prefer watching movies or any content they want on Youtube, MX Player, Netflix, Amazon Prime, etc. of their choice. Therefore, companies prefer to advertise digitally on all these platforms and promote in such places where there is the maximum bandwidth of customers.



- Instead of spending time going to the market and then buying all things, it takes very little time to purchase their favourite things or products on the internet.
- Digital Marketing has not only helped customers, but it has also helped the merchants because in no time they are able to reach a huge bulk of customers which has a rapid effect on their growth parameters.

Digital Marketing Channels:



- **Website Marketing:** It is a powerful medium needed to execute a variety of online marketing campaigns. A website can represent a product, or service in a clear and attractive way and it should be fast, mobile-friendly, and easy to use.
- **Pay-per-Click Advertising:** PPC enables the user to reach Internet users on a number of digital platforms through paid ads. The most popular PPC platforms are Google Ads and Facebook Ads.
- **Content-Marketing:** The goal of content marketing is to reach potential customers through the use of content. Content is usually published on a website and then promoted through social media, email marketing, SEO, or even PPC campaigns.
- Email Marketing: Email marketing is still one of the most effective digital marketing channels. Many people confuse email marketing with spam email messages, but that's not what email marketing is all about. Email marketing is the medium to get in touch with your potential customers or the people interested in your brand.
- **Social Media Marketing:** The primary goal of a social media marketing campaign is brand awareness and establishing social trust. As you go deeper into social media marketing, you can use it to get leads or even as a direct sales channel.

DR. VIRENDRA TIWARI

True and False question and answer:

1. True/False: Information Security primarily focuses on ensuring the availability of information rather than its confidentiality.
    - Answer: False
        - Information Security is a multidimensional field that aims to protect the confidentiality, integrity, and availability of information. While availability is essential, confidentiality is equally crucial.
2. True/False: Malicious programs, such as viruses and worms, are always created with the intent of causing harm to computer systems.
    - Answer: True
        - Malicious programs are typically designed to cause harm, whether it's stealing sensitive information, disrupting system operations, or facilitating unauthorized access.
3. True/False: Cryptography is only concerned with encoding messages and does not play a role in ensuring data integrity.
    - Answer: False
        - Cryptography not only involves encoding messages but also plays a crucial role in ensuring data integrity by detecting any unauthorized modifications to the data.
4. True/False: A digital signature ensures the confidentiality of a message by encrypting its contents.
    - Answer: False
        - A digital signature primarily ensures the authenticity and integrity of a message, confirming that it hasn't been tampered with. It doesn't necessarily encrypt the message for confidentiality.
5. True/False: Firewalls can be both hardware and software-based, providing a barrier between a private network and the external world.
    - Answer: True
        - Firewalls can be implemented as both hardware devices and software applications, serving as a barrier to control and monitor incoming and outgoing network traffic.
6. True/False: User identification is the process of verifying the identity of an individual, while authentication ensures that the identified user has the authorized access.
    - Answer: True
        - User identification is the process of claiming an identity, while authentication verifies that the claimed identity matches the provided credentials and grants authorized access.
7. True/False: Security awareness programs are unnecessary if an organization has robust security policies in place.
    - Answer: False
        - Security awareness programs are essential to educate and inform individuals about security practices, complementing the policies to create a security-conscious culture.

DR. VIRENDRA KUMAR TIWARI

8. True/False: Security policies in an organization should be static and not subject to regular review and updates.
    - Answer: False
        - Security policies should undergo regular review and updates to adapt to evolving threats, technologies, and organizational changes.
9. True/False: All application areas have equal security requirements, regardless of the nature of the data they handle.
    - Answer: False
        - Security requirements vary based on the sensitivity and criticality of the data handled by different application areas.
10. True/False: Mobile commerce is immune to the security challenges faced by traditional e-commerce platforms.
    - Answer: False
        - Mobile commerce introduces new security challenges, including mobile device vulnerabilities, data transmission over wireless networks, and the potential for unauthorized access.
11. True/False: Digital Marketing does not involve the collection and processing of sensitive customer data.
    - Answer: False
        - Digital Marketing often involves the collection and processing of sensitive customer data for targeted advertising and personalized experiences.
12. True/False: The primary role of a firewall is to detect and remove malicious programs from a computer system.
    - Answer: False
        - The primary role of a firewall is to monitor and control incoming and outgoing network traffic based on predetermined security rules, not to detect and remove malicious programs.
13. True/False: Multi-factor authentication involves using a single method to verify a user's identity.
    - Answer: False
        - Multi-factor authentication involves using two or more independent methods to authenticate a user, enhancing security compared to a single method.
14. True/False: Encryption is only necessary for securing data during transmission and is not relevant when data is at rest.
    - Answer: False
        - Encryption is crucial for securing data both during transmission and when it is at rest to prevent unauthorized access.
15. True/False: Security awareness is a one-time effort and does not require continuous reinforcement.
    - Answer: False
        - Security awareness is an ongoing effort that requires continuous reinforcement to address evolving threats and maintain a vigilant organizational culture.
16. True/False: Information Security is solely concerned with preventing external threats.
    1. Answer: False
17. True/False: A computer virus is a type of malicious program that can replicate itself and spread to other computers.

DR. VIRENDRA KUMAR TIWARI

1. Answer: True

18. True/False: Symmetric cryptography uses different keys for encryption and decryption.
    1. Answer: False
19. True/False: A digital signature ensures the privacy of the message content.
    1. Answer: False
20. True/False: Firewalls are designed to protect against physical security threats.
    1. Answer: False
21. True/False: Biometric authentication is a form of multi-factor authentication.
    1. Answer: True
22. True/False: Security awareness programs are unnecessary if an organization has strong technical security measures in place.
    1. Answer: False
23. True/False: Security policies in an organization are static and do not require periodic review.
    1. Answer: False
24. True/False: All application areas have the same level of security requirements.
    1. Answer: False
25. True/False: Mobile commerce introduces new security challenges compared to traditional e-commerce.
    1. Answer: True
26. True/False: Digital Marketing does not involve the collection of user data.
    1. Answer: False
27. True/False: A firewall examines and controls network traffic based on predetermined security rules.
    1. Answer: True
28. True/False: Multi-factor authentication involves using multiple methods to verify a user's identity.
    1. Answer: True
29. True/False: Encryption is only necessary for securing data during transmission.
    1. Answer: False
30. True/False: Security policies in an organization should be regularly reviewed and updated.
    1. Answer: True
31. True/False: Information Security is a one-time effort and does not require continuous attention.
    1. Answer: False
32. True/False: Public-key cryptography relies on a single key for both encryption and decryption.
    1. Answer: False
33. True/False: Phishing is a form of social engineering attack.
    1. Answer: True
34. True/False: Intrusion Detection Systems (IDS) focus on preventing security breaches.
    1. Answer: False
35. True/False: Two-factor authentication is a type of multi-factor authentication.
    1. Answer: True
36. True/False: Access control lists are commonly used in physical security.
    1. Answer: False

37. True/False: A Security Operations Center (SOC) monitors and responds to security incidents.
    1. Answer: True
38. True/False: Honeypots are used to detect and deflect cybersecurity attacks.
    1. Answer: True
39. True/False: Zero-trust security assumes that every user and device is trustworthy.
    1. Answer: False
40. True/False: Security Information and Event Management (SIEM) systems collect and analyze log data for security purposes.
    1. Answer: True
41. True/False: Encryption keys must always be kept secret to maintain the security of encrypted data.
    1. Answer: True
42. True/False: The principle of least privilege suggests giving users the maximum level of access to perform their job functions.
    1. Answer: False
43. True/False: Cross-site scripting (XSS) is a type of network firewall.
    1. Answer: False
44. True/False: Ransomware is a type of malware that encrypts a user's files and demands payment for their release.
    1. Answer: True
45. True/False: A security risk assessment is a one-time process and does not require regular updates.
    1. Answer: False
46. True/False: Data classification is important for determining the level of security protection needed for different types of data.
    1. Answer: True
47. True/False: The separation of duties principle is essential for preventing conflicts of interest in security management.
    1. Answer: True
48. True/False: A VPN is primarily used for physical security.
    1. Answer: False
49. True/False: Security audits are conducted to identify and rectify security vulnerabilities.
    1. Answer: True
50. True/False: Malware can only be spread through infected files.
    1. Answer: False
51. True/False: User training is not effective in preventing security breaches.
    1. Answer: False
52. True/False: Security policies are only relevant for large organizations.
    1. Answer: False
53. True/False: Security controls in physical security are unnecessary in a digital environment.
    1. Answer: False
54. True/False: Social engineering relies on exploiting vulnerabilities in computer systems.
    1. Answer: False
55. True/False: Data encryption is not necessary for data stored on internal servers.
    1. Answer: False

Introduction to Information Security:

1. What is the primary goal of Information Security?
2. Define the term "confidentiality" in the context of Information Security.
3. Why is Information Security essential in the digital age?
4. Name two common threats that Information Security aims to mitigate.
5. How has the significance of Information Security evolved over the years?

Malicious Programs:

6. What is a computer virus, and how does it spread?
7. Differentiate between a virus and a worm.
8. How can users protect their systems from malware attacks?
9. Explain the concept of ransomware and its impact on cybersecurity.
10. Name one famous example of a malware attack and its consequences.

Cryptography:

11. What is the primary purpose of cryptography in Information Security?
12. Explain the difference between symmetric and asymmetric encryption.
13. How does a cryptographic hash function work?
14. Why is key management crucial in cryptographic systems?
15. Provide an example of a widely used cryptographic algorithm.

Digital Signature:

16. What role does a digital signature play in ensuring data integrity?
17. How does a digital signature differ from a handwritten signature?
18. Why is non-repudiation important in digital signatures?
19. Name one application where digital signatures are commonly used.
20. Explain the process of verifying a digital signature.

Firewall:

21. Define the term "firewall" in the context of network security.
22. How does a firewall protect a network from unauthorized access?
23. Differentiate between hardware and software firewalls.
24. Name two types of firewall deployment architectures.
25. Why is a firewall considered the first line of defense in network security?

Users Identification and Authentication:

26. What is the purpose of user authentication in Information Security?
27. Differentiate between single-factor and multi-factor authentication.
28. Explain the concept of biometric authentication.
29. Why is strong password management crucial for user security?
30. Name two common challenges in user authentication.

Security Awareness and Policies:

31. Why is security awareness training important for organizations?
32. How can organizations promote a culture of security awareness among employees?
33. Define the concept of a security policy.
34. Name three elements commonly found in a security policy.
35. How often should security policies be reviewed and updated?

Application Areas Requiring Security:

36. Identify two application areas where security is critical.
37. How does Information Security impact the financial sector?

DR. VIRENDRA KUMAR TIWARI

38. Name a healthcare application that requires robust security measures.
39. Explain the importance of security in e-commerce platforms.
40. In what ways does the education sector benefit from Information Security?

Short answer type question:

1. What is the primary goal of Information Security?
2. Define malicious programs and provide an example.
3. How does Cryptography contribute to Information Security?
4. Explain the concept of a digital signature.
5. What role does a Firewall play in network security?
6. Differentiate between identification and authentication.
7. Why is security awareness important in Information Security?
8. Give an example of a security policy in an organizational context.
9. Identify two application areas that require robust security measures.
10. How does mobile commerce impact Information Security considerations?
11. Name a successful case study in the growth of mobile commerce.
12. Describe a technology commonly used in mobile commerce.
13. In what ways can Digital Marketing be affected by security issues?
14. What are the potential risks associated with users' identification and authentication?
15. Explain the term "encryption" in the context of Information Security.
16. How can a digital signature enhance the integrity of electronic documents?
17. List three common types of malicious programs.
18. Define multi-factor authentication and provide an example.
19. What is the purpose of security policies in an organization?
20. How does Information Security contribute to protecting personal privacy?
21. Why is it essential to regularly update security measures?
22. Provide an example of a security breach and its consequences.
23. How does Information Security contribute to data integrity?
24. Name two challenges in implementing effective security awareness programs.
25. Explain the concept of "least privilege" in user access management.
26. What is the role of penetration testing in Information Security?
27. Describe the difference between symmetric and asymmetric cryptography.
28. How does a VPN contribute to securing communication over the internet?
29. What is the significance of security audits in an organization?
30. Explain the concept of a honeypot in cybersecurity.
31. How can social engineering pose a threat to Information Security?
32. What is the purpose of intrusion detection systems (IDS)?
33. Discuss the importance of user training in preventing security breaches.
34. Describe the role of biometrics in user authentication.
35. How does Security Information and Event Management (SIEM) enhance security?
36. Provide an example of a security incident response plan.
37. Why is it crucial to secure data in transit and at rest?
38. Explain the concept of a zero-trust security model.
39. What are the key components of a well-rounded security awareness program?
40. How does Information Security contribute to business continuity planning?
41. Describe a common method used in phishing attacks.

DR. VIRENDRA KUMAR TIWARI

42. What is the purpose of access control lists in network security?
43. How does the principle of "separation of duties" contribute to security?
44. Discuss the role of encryption in securing email communication.
45. Why is it important to classify data based on sensitivity levels?
46. Explain the concept of a security risk assessment.
47. Provide an example of a security control measure in physical security.
48. How does Information Security align with regulatory compliance?
49. Describe the role of a Security Operations Center (SOC) in cybersecurity.
50. What measures can be taken to secure Internet of Things (IoT) devices?

Long question:

1. What are the fundamental objectives of Information Security, and how have they evolved over time?
2. Explain the concept of the CIA Triad in the context of Information Security.
3. How does Information Security contribute to the overall risk management strategy within an organization?
4. Provide an in-depth analysis of different types of malicious programs and their specific functionalities.
5. Discuss the evolution of malware and the challenges it poses to modern Information Security.
6. Explore the history and evolution of cryptography as a cornerstone of Information Security.
7. How does quantum computing pose a potential threat to traditional cryptographic systems?
8. Explain the process of creating and verifying digital signatures, highlighting their role in ensuring data integrity.
9. Discuss the legal implications and acceptance of digital signatures in various jurisdictions.
10. Provide a detailed overview of how Firewalls operate and their role in network security.
11. Explore the challenges and solutions associated with securing modern, complex network architectures.
12. Discuss the importance of strong user authentication methods and their role in preventing unauthorized access.
13. How do emerging technologies, such as biometrics, impact user identification and authentication?
14. Analyze the significance of security awareness programs in cultivating a culture of cybersecurity within organizations.
15. Outline the key components of an effective security policy and its role in mitigating risks.
16. Explore the specific security challenges faced by healthcare applications and the measures taken to address them.
17. Discuss the unique security considerations for financial applications, considering the sensitive nature of financial data.
18. Investigate the growth trends of mobile commerce and the security challenges associated with mobile transactions.
19. Provide a case study on a successful implementation of secure mobile commerce in a specific region.
20. Analyze the intersection of Information Security and Digital Marketing, focusing on data privacy concerns.

DR. VIRENDRA KUMAR TIWARI

21. Discuss the role of secure communication channels in ensuring the integrity of digital marketing campaigns.
22. What are the foundational principles of Information Security, and how do they shape the development of comprehensive security strategies within organizations?
23. Delve into the intricate world of malicious programs: from their classification to the methodologies employed in safeguarding against them, explore the evolving landscape of cyber threats.
24. In-depth exploration of Cryptography: Unravel the complexities of encryption algorithms, key management, and the pivotal role cryptography plays in securing sensitive information across various communication channels.
25. Illuminate the concept of a digital signature, its applications in ensuring data integrity and authenticity, and the cryptographic mechanisms that underpin its effectiveness in modern digital transactions.
26. Firewall technologies are critical in fortifying network security. Analyze the different types of firewalls, their functionalities, and the evolving challenges they face in an era of sophisticated cyber attacks.
27. Users Identification and Authentication form the cornerstone of access control. Delve into the intricacies of biometrics, multi-factor authentication, and explore innovative methods ensuring secure user verification.
28. How does Security Awareness transcend mere technical implementations? Examine the human factor in Information Security, exploring the psychology of cyber threats and the role of education in fostering a security-conscious culture.
29. Security policies are the bedrock of organizational security. Discuss the formulation, implementation, and ongoing evaluation of security policies, considering the dynamic nature of cyber threats and technological advancements.
30. Explore the diverse application areas that necessitate robust security measures, ranging from financial institutions to healthcare systems, and discuss the unique challenges each sector faces in safeguarding sensitive information.
31. The proliferation of mobile commerce introduces new dimensions to Information Security. Investigate the growth, success stories, and the underlying technologies driving mobile commerce, with a specific focus on security considerations.
32. Dive into the intersection of Digital Marketing and Information Security. Examine the vulnerabilities and risks associated with digital marketing practices and propose strategies to integrate security seamlessly into promotional activities.
33. In a rapidly evolving technological landscape, discuss the emerging trends and future challenges in Information Security, considering the increasing sophistication of cyber threats and the imperative to stay ahead of potential risks.

DR. VIRENDRA KUMAR TIWARI

Descriptive question:

1. **Information Security Introduction:**
   - Explore the evolution of Information Security over the years, detailing key milestones and the changing threat landscape. How has the perception and importance of Information Security transformed in contemporary society?
2. **Malicious Programs:**
   - Investigate the various types of malicious programs, such as viruses, worms, and Trojans. How do these programs infiltrate systems, and what are the potential damages they can cause to both individual users and large-scale enterprises?
3. **Cryptography:**
   - Delve into the foundational principles of cryptography, examining how encryption algorithms contribute to data security. Explain the difference between symmetric and asymmetric cryptography and provide real-world examples of their applications.
4. **Digital Signature:**
   - Unpack the concept of digital signatures, elucidating their role in ensuring the authenticity and integrity of digital messages. How do digital signatures work, and in what scenarios are they particularly crucial for secure communication?
5. **Firewall:**
   - Analyze the functionalities and types of Firewalls, detailing how they establish a barrier against unauthorized access. Explore the challenges of implementing Firewalls in diverse network architectures and their role in protecting against different types of cyber threats.
6. **Users Identification and Authentication:**
   - Investigate the methods of user identification and authentication, considering the strengths and weaknesses of various approaches. How does multi-factor authentication enhance the security of user accounts, and what challenges arise in managing user identities at scale?
7. **Security Awareness and Policies:**
   - Examine the role of security awareness programs in fostering a culture of cybersecurity within organizations. How do security policies contribute to standardizing security practices, and what are the key elements of an effective security awareness campaign?
8. **Application Areas Requiring Security:**
   - Explore specific industries or application areas that demand robust security measures, such as healthcare, finance, or critical infrastructure. How do the security requirements vary across these domains, and what unique challenges do they face in safeguarding sensitive information?
9. **Mobile Commerce:**
   - Investigate the growth of mobile commerce globally and its implications for Information Security. How do technologies such as mobile payment systems contribute to the challenges and opportunities in securing financial transactions conducted through mobile devices?
10. **Digital Marketing:**
    - Examine the intersection of Digital Marketing and Information Security. What security considerations should businesses and marketers account for in the era of data-driven advertising and personalized customer experiences?

DR. VIRENDRA KUMAR TIWARI

Information Security:

Remember (Knowledge)

1. **Define Information Security and list its key objectives.**
2. **Name three types of malicious programs and provide brief descriptions of each.**
3. **Define cryptography and explain its role in securing information.**
4. **Describe the purpose and function of a digital signature.**
5. **List two types of firewall and explain how they contribute to information security.**

Understand (Comprehension)

6. **Explain the potential threats posed by malicious programs to information security.**
7. **Discuss the principles of cryptography and how it protects data confidentiality.**
8. **Explain the concept of digital signatures in ensuring the integrity of electronic documents.**
9. **Describe the role of firewalls in preventing unauthorized access to computer networks.**
10. **Discuss the importance of user identification and authentication in information security.**

Apply (Application)

11. **Devise a plan for preventing the spread of malicious programs within a corporate network.**
12. **Design a cryptographic system for securing sensitive communications in a business setting.**
13. **Create a digital signature for a document to ensure its authenticity and integrity.**
14. **Implement a firewall configuration to protect a network from external threats.**
15. **Develop a user identification and authentication mechanism for a web-based application.**

Analyze (Analysis)

16. **Analyze the impact of malicious programs on data integrity and system functionality.**
17. **Evaluate the strengths and weaknesses of different cryptographic algorithms.**
18. **Examine the legal and ethical implications of digital signatures in e-commerce.**
19. **Analyze the effectiveness of firewalls in preventing various types of cyber attacks.**
20. **Evaluate the importance of strong user identification and authentication methods in preventing unauthorized access.**

Evaluate (Evaluation)

21. **Evaluate the effectiveness of current strategies in combating malicious programs.**
22. **Assess the security risks associated with different cryptographic techniques.**
23. **Evaluate the legal implications of using digital signatures in electronic transactions.**
24. **Assess the strengths and limitations of firewalls in protecting against evolving cyber threats.**
25. **Evaluate the usability and security trade-offs of user identification and authentication methods.**

Create (Synthesis)

26. **Develop a comprehensive information security policy for a small business.**
27. **Design a secure communication protocol for transmitting sensitive information over the internet.**
28. **Create a digital marketing campaign to raise awareness about the importance of information security.**
29. **Design a multi-layered security architecture for a large corporate network.**
30. **Develop a user-friendly yet secure authentication system for an online banking application.**

Mobile Commerce:

Remember (Knowledge)

31. **Define Mobile Commerce (M-commerce) and list its key characteristics.**
32. **Name two technologies commonly used in mobile commerce.**
33. **Provide an example of a successful mobile commerce business.**

Understand (Comprehension)

34. **Explain the factors contributing to the growth of mobile commerce.**
35. **Discuss the success stories of specific mobile commerce ventures.**
36. **Describe the technologies enabling mobile commerce transactions.**

DR. VIRENDRA KUMAR TIWARI

Apply (Application)

37. **Develop a strategy for integrating mobile commerce into a traditional retail business.**
38. **Create a mobile commerce app for a small business.**
39. **Implement a location-based marketing campaign for a mobile commerce platform.**

Analyze (Analysis)

40. **Analyze the impact of mobile commerce on traditional brick-and-mortar businesses.**
41. **Examine the factors contributing to the success of specific mobile commerce businesses.**
42. **Evaluate the security challenges associated with mobile commerce transactions.**

Evaluate (Evaluation)

43. **Evaluate the economic impact of mobile commerce growth in India.**
44. **Assess the success factors of a mobile commerce business in a specific industry.**
45. **Evaluate the effectiveness of security measures in ensuring safe mobile commerce transactions.**

Create (Synthesis)

46. **Design a mobile commerce platform that incorporates the latest technologies.**
47. **Create a business plan for a startup focusing on mobile commerce.**
48. **Develop a comprehensive digital marketing strategy for a mobile commerce app.**

DR. VIRENDRA KUMAR TIWARI